

Received 24 April 2026, accepted 13 May 2026, date of publication 20 May 2026, date of current version 27 May 2026.

Digital Object Identifier 10.1109/ACCESS.2026.3695458

RESEARCH ARTICLE

Provably Adaptive Trust Dynamics in Context-Aware Zero-Trust Systems: A Formal Framework for Continuous Verification

VIVIN KRISHNAN¹ AND C. S. SREEJA², (Senior Member, IEEE)

¹Department of Computer Science, CHRIST (Deemed to be University), Bengaluru, Karnataka 560029, India

²Center for Quantum Technologies and Complex Systems (CQTCS), CHRIST (Deemed to be University), Bengaluru, Karnataka 560029, India

Corresponding author: Vivin Krishnan (vivin.krishnan@res.christuniversity.in)

ABSTRACT Zero-Trust (ZT) requires continuous, context-aware evaluation of authentication and authorization decisions. This paper introduces Zero-Trust Hybrid Adaptive Authentication (ZeTHAA), a continuous authentication and authorization framework integrating contextual attributes, authentication strength, behavioral evidence, and retry dynamics. ZeTHAA utilizes a probabilistic risk model and dual-policy thresholds to partition outcomes into allow, step-up, and block regions, enabling precise control over security–usability trade-offs. The system introduces a global admissibility predicate to distinguish hard violations from probabilistic soft violations. Attribute importance is dynamically derived from entropy and Beta-posterior distribution, enabling robust cold-start initialization and online recalibration. ZeTHAA presents a unified composite attack surface covering credential compromise, attribute forgery, and post-grant hijacking, modeling retry behavior with exponential risk escalation and temporal decay. A large-scale synthetic dataset capturing realistic authentication flows, adversarial and temporal patterns, was used to evaluate ZeTHAA against heuristic, logistic regression, random forest, XGBoost, and isolation forest baselines. ZeTHAA produced a more expressive risk distribution and significantly higher attack detection and efficiency while minimizing user friction. ZeTHAA outperformed baseline models, with Recall and Area Under the Curve (AUC) exceeding 79% and 15.1%, respectively. F1-Score showed increases of 48%-147%, with efficiency boost of 20-65%, while reducing the cost per attack by up to 39.6%. Benchmarks against frameworks from Dasu et al. and Matiushin et al. showed a 57.5% lead in F1-Score, more than double increase in detection rate, while blocking 70.78% more attacks. Additional analysis shows that ZeTHAA provides a mathematically grounded foundation for Zero-Trust systems, aligns with NIST standards, offering improved security guarantees and adaptive enforcement.

INDEX TERMS Adaptive authentication, application integrity check, Bayesian online learning, continuous authentication, device authentication, dynamic secret injection, risk-based access control.

I. INTRODUCTION

Single-factor authentication (SFA) schemes have been the mainstay of authentication because of their usability and ease of implementation [1]. However, as computing resources and threat vectors become increasingly sophisticated, attacks on SFA systems have become commonplace [2], [3]. With SFA, the attacker must focus on breaking only a single authentication method [4].

The associate editor coordinating the review of this manuscript and approving it for publication was Sedat Akleyek¹.

The need for secure authentication accelerated the development of multifactor authentication (MFA) systems, which are more secure [5], [6]; however, MFA remains a static approach that relies on sequential chaining of authentication challenges [7]. Blancaflor et al. [8] reported sophisticated attack measures that specifically target MFA systems. The layering of challenges also contributes to user friction and reduces usability and adoption [9]. Traditional MFA techniques, while effective in bolstering security, frequently lead to “MFA fatigue” and user frustration due to repetitive prompts, even in low-risk scenarios [10].

Consequently, Adaptive Authentication (AA) systems, which utilize users' behavioral and contextual patterns to challenge users sparingly when behavior deviates from established patterns, have gained popularity [11]. AA incorporates contextual signals such as device posture, geolocation, behavioral biometrics, and network attributes to compute dynamic risk scores. When the behavioral context of a request varies from the established profile, the system selects an alternative authentication modality to challenge the user. The complexity of the selected alternative authentication modality is proportional to the risk of malicious agents accessing resources. In contrast to MFA, AA employs a dynamic strategy in which risk factors are considered when selecting the subsequent action. This evolution in security design is largely driven by the inherent tension between achieving robust protection and maintaining enhanced user experiences [12].

As authentication systems began to incorporate adaptive and risk-based authentication (RBA), a new cybersecurity design paradigm, i.e., zero-trust (ZT), evolved in parallel, with many enterprises adopting it as the driving principle. ZT, which revolves around the principle of "never trust, always verify", ensures that no implicit trust is assigned to users or resources regardless of location (physical or network) [13].

However, many risk-based systems rely on heuristic or proprietary scoring mechanisms, and they typically lack a formalized mathematical model governing trust accumulation, decay, and re-evaluation over time. This gap motivates a transition from authentication-centric security to architectural paradigms that assume persistent adversarial presence.

This paper presents ZeTHAA - a novel convergence of Zero-Trust philosophy into Adaptive and Continuous Authentication. This work is based on the hypothesis that incorporating policy-aware, multi-threshold decision mechanisms into risk-based authentication systems leads to improved operational outcomes compared to traditional single-threshold approaches. The proposed Zero-Trust-based hybrid Adaptive Authentication system operates on a composite attribute set that covers all participating discrete entities. The system covers the actor, the medium of access, and the platform it runs, establishing a "who - uses what - on which" relationship. This allows for the collection of a wider range of attributes while employing a minimally invasive profile. The hybrid nature of the proposed system enables the validation of contextual attributes, grouped by their composition, in parallel, thereby allowing faster outcomes. The key contributions of this paper are:

- Formalization of trust as a continuous, time-evolving, and bounded state variable rather than a binary policy-based outcome.
- Assurance-aware Trust initialization, integrating authentication and identity strengths.
- Contextual Risk aggregation framework that integrates multi-dimensional contextual signals (device

posture, behavioral context, access medium, application attributes, and threat indicators) and transforms them into a normalized risk metric for trust evolution.

- Trust evolution with reinforcement and temporal decay dynamics.
- Parameterization and recalibration of weighting and penalty coefficients.
- Explicit mapping of trust state to policy decisions within Zero Trust architecture.
- Standards-aligned architectural integration, including identity, application, and device trust considerations.
- Formulate and evaluate a hypothesis that policy-aware multi-threshold authentication improves the trade-off between security and usability.

The remainder of this paper is organized as follows. Section II outlines the research questions and hypotheses guiding the proposed framework. Section III presents the foundational principles of Zero Trust Architecture and relevant standards. Section IV presents a detailed analysis of the existing literature in the field and identifies key research gaps. Section V discusses the methodology of the proposed ZeTHAA framework and formulates the trust evolution model. Section VI formalizes the security guarantees of the ZeTHAA framework, followed by experimental evaluation and findings in section VII. Finally, Section VIII concludes the paper.

II. RESEARCH QUESTIONS AND HYPOTHESES

We establish the theoretical foundation by presenting the research questions and hypotheses that underpin the proposed framework.

A. RESEARCH QUESTIONS

AA and RBA systems have traditionally focused on improving classification accuracy through enhanced risk estimation using heuristic or machine-learning approaches. However, real-world authentication systems must balance security (attack detection) with usability (user friction and cost), with decisions governed by policies rather than risk scores alone.

In this context, this work is guided by the following research questions:

- **RQ1:** Does incorporating policy-aware, multi-threshold decision mechanisms improve the trade-off between security and usability compared to traditional single-threshold RBA approaches?
- **RQ2:** Can multi-stage decision regions (allow, step-up, block) reduce false blocking rates without significantly degrading attack detection performance?
- **RQ3:** Does the calibration of model outputs to operational thresholds improve the alignment between risk estimation and authentication decisions?

These questions aim to shift the focus from risk prediction alone to decision effectiveness under operational constraints.

B. RESEARCH HYPOTHESES

Based on the above research questions, we formulate the following hypotheses:

- **H1 (Trade-off Hypothesis):** A policy-aware, dual-threshold authentication framework achieves a better balance between security and usability than single-threshold AA or RBA approaches.
- **H2 (Decision Structure Hypothesis):** Multi-threshold decision regions reduce false-blocking rates while maintaining comparable or improved attack-detection performance.
- **H3 (Calibration Hypothesis):** Calibration of model outputs to policy thresholds improves the alignment between risk scores and authentication decisions, enabling more effective utilization of decision regions.

C. HYPOTHESIS EVALUATION STRATEGY

The hypotheses were evaluated through a comprehensive experimental framework using a held-out test dataset. Each hypothesis is tested using specific metrics:

- **Operational Trade-off (H1):** Assessed using cost-based metrics, step-up rate, block rate, and false block rate, capturing the balance between security enforcement and user friction.
- **Discrimination Performance (H2):** Evaluated using Receiver Operating Characteristic (ROC) curves, Area Under the Curve (AUC), and Equal Error Rate (EER), which measure the ability to distinguish between benign and malicious events.
- **Decision Alignment (H3):** Analyzed through calibrated risk score distributions, decision boundary analysis, and region-wise behavior (allow, step-up, block), demonstrating how well model outputs align with policy thresholds.

A comparative evaluation was conducted against heuristic and machine learning-based baselines to validate the proposed hypotheses.

Together, these research questions and hypotheses establish a framework for evaluating authentication systems not only in terms of predictive accuracy, but also in terms of decision quality, operational efficiency, and real-world applicability.

III. ZERO TRUST ARCHITECTURE AND STANDARDS CONTEXT

A. ZERO TRUST ARCHITECTURE

The Zero Trust paradigm operates on the tenet of “no implicit trust”. ZT assumes that no entity is trustworthy, regardless of user identity, network, or device posture. The key principles and components of the Zero Trust Architecture (ZTA) have been formalized by the National Institute of Standards and Technology under NIST SP 800-207 [13]. ZTA mandates continuous authentication, and verification of identity, device, and contextual attributes across all data points at all times before granting access to protected resources.

The core principles of ZTA include:

- Elimination of implicit trust
- Least privilege access enforcement
- Strict authentication and authorization actions
- Continuous evaluation of signals for data-driven decisions
- Dynamic Policy-driven decision mechanisms

Under the ZTA, trust is treated as dynamic and contextual rather than static and rule-driven. Access decisions are evaluated by policy engines that analyze continuous data supplied across sources. However, while ZTA articulates architectural components—policy enforcement points, policy decision points, and trust signal collectors—it does not formally define a quantitative trust function or a methodology for continuous trust evolution.

B. IDENTITY ASSURANCE AND AUTHENTICATOR STRENGTH

NIST SP 800-63, referred to as “Digital Identity Guidelines”, standardizes authentication and identity proofing for private and public sector enterprises. It covers a Risk Management Framework, along with Identity and authentication life cycle management, assurances, and assertions [14].

This framework defines Identity Assurance Levels (IAL), Authenticator Assurance Levels (AAL), and Federation Assurance Levels (FAL) for identity proofing and authentication strength. AAL defines metrics that characterize the strength of an authentication process. AALs 1-3 offer an indicator of confidence in an authentication method. Higher assurance levels (e.g., AAL2 and AAL3) mandate stronger authenticators, including cryptographic hardware-bound credentials.

Although these standards help choose authentication methods based on security needs, they remain largely focused on the strength of the authentication event itself. Assurance levels do not specify how trust should decay, accumulate, or be recalibrated during an active session, nor do they address the dynamic threat conditions that emerge after session establishment.

C. PHISHING-RESISTANT AUTHENTICATION AND FIDO

The FIDO Alliance and W3C’s work on phishing-resistant and largely passwordless authentication methods resulted in the FIDO2 framework and the WebAuthn standard [15].

FIDO-based authentication aims to eliminate or replace shared secrets such as passwords or OTPs with public-key cryptography, where private keys are securely bound to user devices and never transmitted over the network. By leveraging device-bound hardware credentials, this architecture provides strong resistance to phishing attacks, credential replays, etc., significantly strengthening authentication.

Nevertheless, similar to other authentication mechanisms, FIDO aims to secure the authentication event rather than defining continuous trust evaluation mechanisms throughout the life of authenticated sessions. They do not provide formal

models for adaptive trust recalibration or continuous risk aggregation.

D. ARCHITECTURAL GAPS IN STANDARDS-BASED ZERO TRUST IMPLEMENTATIONS

Zero Trust architecture and identity assurance standards provide a robust framework for secure access control. However, they do not define a computational model for trust evaluation and recalibration. This results in implementations relying on arbitrary or heuristic scoring approaches.

- Trust is treated as a policy outcome rather than as a continuously monitored, measurable, and evolving variable.
- There is no formal definition of how contextual signals from different sources are aggregated and transformed into quantitative trust metrics.
- The parameterization of reinforcing weights or degrading penalties and their formulation is not defined.
- Trust decay, recalibration, and convergence during ongoing sessions are not modeled formally.

These limitations highlight a critical research gap: the lack of a formal mathematical framework capable of modeling continuous, adaptive trust computation within Zero Trust architectures. The following section surveys existing academic approaches that attempt to address aspects of this problem and identifies the remaining challenges that motivate the proposed model.

IV. RELATED WORK

Strong security systems have been a priority area of research in both industry and academia, and previous studies on implicit authentication using behavioral metrics set the path towards AA.

A. RISK-BASED AND ADAPTIVE AUTHENTICATION

Risk-based authentication (RBA) and Adaptive Authentication (AA) for systems have been a growing focus of study. RBA focuses on risk analysis using contextual and behavioral signals, comparing them with the user's historical profile, and derives a risk score. The risk score determines which authenticators will be employed to challenge the user. Adaptive authentication focuses on choosing authenticators to activate based on the risk score derived from behavioral and contextual analysis. They represent an "at the point of authentication" phase.

Dasu et al. [16] proposed an Adaptive Authentication framework to defend against identity threats. However, the authors adopt a heuristic approach to weight assignment, in which risk signal weights are assigned statically and are independent of the data distribution and attack history. Furthermore, the variance computation is performed only on the last 10 login records, limiting the scope of variance computation to strictly heuristic and not statistical. Picard and Pierre [17] presented an RBA system that uses deep reinforcement learning (DRL) to select authentication

modalities based on a user's context. The work concentrated on access to mobile device applications based on user context and resource sensitivity. Although the DRL approach enables rapid learning and inference, the system lacks cold-start initialization when no prior data are available.

An RBA implementation for OpenStack was presented by Unsel et al. in [18]. This study attempts to mitigate the low adoption rates of RBA. However, the framework uses only the IP address, round-trip-time(RTT), and User-Agent to evaluate variance from baseline behavior. Matiushin et al. proposed Machine Learning-Empowered Risk-Based Authentication (MLE-RBA), a LightGBM-based RBA framework, in [19]. Although MLE-RBA operates on a dynamically computed binary threshold, it focuses on the mathematical optimality and does not account for user friction in the outcome. In addition, the framework assumes that prior data is available to compute the threshold. Further studies on risk-based and AA have been proposed by [20], [21], [22], [23], [24], and [25] that utilize various attributes such as usage patterns, behavioral biometrics, and smartphone usage. However, these studies propose binary decision-making systems based on singular behavioral aspects, that are individually susceptible to spoofing.

RBA and AA systems focus on the authentication phase, and not beyond into post-login authorization requests, token grants, and resource requests. This is handled by continuous authentication systems.

B. CONTINUOUS AUTHENTICATION

Continuous authentication (CA) systems focus on validating a user's identity while a user session is in progress.

Acar et al. [26] presented a wearables-assisted CA framework that verifies user identity based on keystroke dynamics detected by sensors. The work proposed by Buriro et al. [27] used keystroke dynamics and touch-timing differences to continuously authenticate users throughout active sessions. The framework distinguishes itself from others by not requiring users to memorize a fixed password. Shen et al. presented a behavioral biometrics-based CA system for smartphones [28]. Liang et al. [29] investigated the use of wearable-device behavioral biometrics for continuous authentication, in which ML was employed to derive behavioral patterns from biometric data. In [30], Mekni et al. presented a study in which CA was achieved using gait biometrics and was enhanced using machine learning. The authors employed a deep-learning-based classifier to enhance authentication accuracy. Shah et al. in their study on continuous device-to-device authentication proposed a lightweight CA framework that utilizes channel properties to dynamically rotate session keys [31]. Similar studies in CA highlight the growing interest in monitoring behavioral aspects for user identity verification, with a focus mainly on wearables and mobile devices [32], [33], [34], [35]. While promising, the proposed CA systems effectively work on binary decision controls, where the user request is either treated as benign or

asked to step up their authentication. Hard violations, such as impossible travels, and cryptographic binding violations, are not considered. In addition, decisions are made by evaluating data from limited behavioral attributes, which can be spoofed individually, and by assuming that historical data will be present as the system is online.

Furthermore, established products in the cybersecurity domain, such as RSA Cybersecurity, CA Risk Authentication, Okta, BIO-Key Portal Guard, Duo Risk-Based Authentication, and IBM Security, employ risk-based AA systems. However, the detailed working patterns of these products, including the attributes they gather and the methods employed to create the contextual profile, are proprietary.

C. ZERO-TRUST SYSTEMS

Zero-trust, as a design philosophy, is being rapidly evaluated and adopted by researchers and industry.

Hasan et al. in their study [36] presented design and assurance patterns for ZT components. With pattern libraries enriched with their findings, the authors claim that system architects can model ZT transformations of Cyber-Physical systems. The authors in [37] proposed a process-driven framework for migrating to a ZT architecture, aimed at addressing the gaps and challenges identified in previous ZT migrations. A similar study on the cost-effectiveness of ZT transformation for organizational security was published by Adahman et al. [38]. Similar studies on ZT transformation of industry sectors have been published in [39], [40], [41], and [42].

Hale et al. [43] presented a ZT-based mitigation approach for ML components originating from data or model manipulation. In addition, Krishnan and Sreeja [44] proposed a zero-trust-based adaptive authentication system that uses composite attribute sets. Ahmed et al. in their work [45] presented a ZT-based access control system to guard sensitive data stores. The authors utilized an access-control proxy to analyze request parameters and arrive at the enforcement decisions. A ZT-based implementation of security measures for Oracle ERP cloud was studied by the authors in Qazi and Arshad [46]. In contrast, a framework to protect power grids from security attacks using a Zero-Trust strategy was discussed by Faraj [47]. Similar zero-trust frameworks for protecting resources have been featured in the literature [48], [49].

D. RESEARCH GAP ANALYSIS

Based on the inference derived from the literature review, the following research gaps have been identified, which need to be addressed:

1) **Vendor-locked, opaque implementation:**

Existing Zero-Trust implementations are proprietary, resulting in vendor lock-in, and do not offer a view of internal working and calibrations [50], [51], [52], [53].

2) **Static attribute weighting and penalty policies:**

Attribute importance, spoofability, and temporal stability are set by fixed rules or expert heuristics. Systems lack cold-start strategies and online recalibration methods [16], [54], [55].

3) **Implicit Trust:**

Risk evaluation and trust computations are performed only until the point of authentication. Post-login requests are implicitly deemed valid and fall within the realm of implicit trust [17], [18], [19].

4) **Lack of an explicit admissibility/safety invariant.**

Industry controls (e.g., impossible travel checks, attestation failures) are often implemented as scattered heuristics. There is little formal distinction between non-compensable (hard) failures and probabilistic (soft) evidence, which complicates correctness arguments and policy proofs.

5) **Poor integration of retry/attack dynamics into threat models.**

Retry behavior (failed logins, repeated attempts) is frequently handled by synthetic counters or lockout rules; few approaches model retries as probabilistic amplifiers of attack likelihood with time decay and contextual consistency checks.

6) **Insufficient adversary-aware threat surfaces.**

Composite attack surfaces that combine authentication, attribute forgery, token replay, and post-grant hijack are rarely modeled together; as a result, policy thresholds are hard to justify quantitatively.

Based on the literature review, the identified research gaps highlight the need to develop an AA system that covers the following factors.

- 1) Discards implicit trust.
- 2) Models trust as a continuous, evolving, and bounded variable
- 3) Multi-dimensional contextual signals for risk aggregation and policy-driven thresholds-based evaluation.
- 4) Enables parameterization and online recalibration of attribute and authentication weighting and penalty coefficients.
- 5) Resists profile poisoning.
- 6) Distinguishes between hard violations and probabilistic soft violations.
- 7) Incorporates retry attack dynamics into threat models.
- 8) Aligned to industry standards.

The proposed ZeTHAA system is an extension of the work of Krishnan and Sreeja [44] to mitigate identified research gaps with an implemented proof-of-concept.

V. METHODOLOGY

This section presents the methodology underlying the proposed Zero-Trust Hybrid Adaptive Authentication (ZeTHAA) framework. The methodology proceeds from system definition and state modeling to threat analysis, risk computation, adaptive enforcement, and security guarantees.

A. NOTATION

Table 1 summarizes the symbols and notations used throughout this study.

B. SYSTEM MODEL

The system consists of a set of protected resources $R = \{R_1, R_2, \dots, R_n\}$. Each resource R_i is associated with a required trust threshold $T(R_i)$, which must be achieved before access is granted. A set of registered users U interacts with the system by performing actions $Act = \{\text{login, read, write}\}$ on the resources in R .

Access decisions are determined under a Zero Trust model, in which no user, device, or session is implicitly trusted. Each access request is evaluated based on:

- A set of contextual and behavioral attributes $\mathcal{A}_t = \{a_1(t), a_2(t), \dots\}$;
- A set of supported authentication methods $\mathcal{M}$, each associated with an intrinsic authentication strength;
- A dynamically evaluated session context $C(t)$, comprising attributes, authentication state, and historical evidence;
- A trust score $\text{Trust}(C(t))$ and an estimated attack success probability $\text{Pr}[\text{Attack Success} \mid C(t)]$.

Authorization decisions are issued per session and per resource, and are continuously re-evaluated as the context evolves.

The ZeTHAA framework defines the Zero-Trust Adaptive Authentication system as the tuple:

$$\mathcal{Z} = (U, A, M, C, R, T)$$

where:

- U denotes the set of users,
- $\mathcal{A} = \{a_1, a_2, \dots, a_n\}$ denotes the set of contextual and behavioral attributes,
- $\mathcal{M} = \{m_1, m_2, \dots, m_k\}$ denotes the set of supported authentication methods,
- C denotes session context,
- $R \in \{0, 1\}$ denotes the observed security outcome,
- $T \in \mathbb{R}$ denotes the trust score.

The tuple $\mathcal{Z}$ defines the system's static structure. Dynamic behavior is captured by explicitly modeling the session context $C(t)$, the trust score $T(t)$, and the observed outcomes $R(t)$ as time-dependent variables.

The high-level architecture of the proposed system is presented in Fig. 1:

C. ASSUMPTIONS AND DESIGN SCOPE

The proposed framework is built on a set of system, threat, and modeling assumptions that enable the formalization of trust, risk, and attack probability. These assumptions are aligned with Zero Trust principles and standard identity frameworks such as NIST SP 800-207 and SP 800-63B.

1) SYSTEM AND TRUST MODEL ASSUMPTIONS

- **Continuous Evaluation.** Trust is evaluated at every request and is not persistent across sessions. Each request is treated as a fresh evaluation under Zero Trust semantics.
- **Composite Trust Function.** Trust is a unified function of authentication strength, contextual attributes, and behavioral history. No independent trust components (e.g., authentication-only or behavior-only trust) exist in isolation.
- **Separation of Trust and Risk.** Trust and risk are complementary but distinct quantities. Trust represents confidence in legitimacy, whereas risk represents the likelihood of adversarial success. The decisions are based on both quantities.

2) ATTRIBUTE AND CONTEXT ASSUMPTIONS

- **Attribute Observability.** Contextual attributes (device, location, time, network, etc.) are observable with bounded noise and may exhibit natural variability.
- **Spoofability and Stability.** Each attribute is associated with a spoofability likelihood and temporal stability, which influences its weight and penalty in trust computation.

3) BEHAVIORAL AND LEARNING ASSUMPTIONS

- **Behavioral Profiles are Probabilistic.** User behavior is modeled as a probabilistic distribution derived from historical observations rather than deterministic rules.
- **Temporal Drift.** Legitimate user behavior evolves over time, and the system accommodates this evolution through bounded learning rates and windowed updates.

4) ADVERSARY AND THREAT MODEL ASSUMPTIONS

- **Polynomial-time, probabilistic Adversary Model.** The adversary's success is modeled probabilistically through authentication breakability, attribute forgery, and post-authentication attack vectors.
- **Retry Behavior as Attack Signal.** Repeated authentication failures are treated as probabilistic indicators of adversarial activity and contribute to risk through retry amplification functions.
- **Hard vs Soft Violations.** Hard violations represent non-compensable failures (e.g., cryptographic failure, impossible travel), while soft violations represent probabilistic deviations that reduce trust but do not terminate the session.

5) OPERATIONAL ASSUMPTIONS

- **Availability of Logging and Telemetry.** Sufficient logging and telemetry are available to estimate attribute distributions, behavioral profiles, and attack probabilities.

TABLE 1. Summary of notations.

Notation	Description
$\mathcal{Z} = (U, A, M, C, R, T)$	Zero-Trust Adaptive Authentication (ZTAA) system definition
U	Set of users
$A = \{a_1, \dots, a_n\}$	Set of contextual and behavioral attributes
a_i	Individual attribute (e.g., User-Agent, GeoIP, device identifier)
$M = \{m_1, \dots, m_k\}$	Set of supported authentication methods
m	Authentication method
$S(m)$	Authentication strength of method m
$\text{Rel}(m)$	Reliability of authentication method m
$\text{PR}(m)$	Phishing resistance indicator of method m
$C(t)$	Session context at time t
R_s	Resource sensitivity
D_p	Device posture
N_s	Network state
$T_c(t)$	Temporal context
L_c	Location context
$R(t) \in \{0, 1\}$	Observed security outcome at time t (1 = attack success, 0 = benign)
$\text{Risk}(C)$	Estimated contextual risk: $\Pr(R = 1 \mid C)$
$T(t)$	Trust score at time t
$\mathcal{S}(t) = (u, m, t_0, t_e, \sigma)$	Authentication session
u	Authenticated user
t_0, t_e	Authentication session start and expiration times
σ	Authentication session state
$\mathcal{A}(t)$	Authorization decision at time t
$\mathcal{E}_a(t)$	Authorization event at time t
$\mathcal{T} = (u, s, \ell, \tau_e, \kappa)$	Authorization token
s	Session identifier associated with token
ℓ	Authorization scope or privileges
τ_e	Authorization token expiration time
κ	Cryptographic or contextual token binding
$\text{TokenValid}(\mathcal{T}, C)$	Predicate indicating validity of token under context C
E_i	Entropy (uniqueness) of attribute a_i
S_i	Spoofability of attribute a_i
D_i	Temporal stability of attribute a_i
ρ_i	Risk correlation of attribute a_i : $\Pr(R = 1 \mid a_i)$
$\text{Risk}(a_i)$	Risk contribution of attribute a_i
$\Pr[\text{Break}(m)]$	Probability of compromising authentication method m
$\Pr[\text{Forge}(a_i)]$	Probability of forging attribute a_i
$\Pr[\text{Attack Success} \mid C]$	Probability of successful attack under context C
$S_{\text{req}}(t)$	Required authentication strength at time t
$\delta, \delta_1, \delta_2$	Risk thresholds for authorization decisions
$\mathcal{E}_g(t)$	Authorization grant event at time t
$\mathcal{E}_r(t)$	Resource access event at time t
$\Pr[\text{Attack}_{\text{auth}}]$	Probability of authentication-phase attack
$\Pr[\text{Attack}_{\text{authz}}]$	Probability of authorization-phase attack
ϕ, ψ	Trust decay and recovery coefficients
α, β, γ	Trust score weighting parameters
$\lambda_1, \lambda_2, \lambda_3$	Attribute risk weighting parameters
ω_i	Contextual risk weighting coefficients

- **Policy-Driven Thresholds.** Thresholds for authentication, authorization, and escalation are defined by system policy and may vary according to resource sensitivity.

6) DEVICE CAPABILITIES

Every request is assumed to originate from a client device capable of:

- **Contextual Signal Provisioning:** The device can provide contextual attributes such as location (coarse or fine-grained), device characteristics, and application metadata. These attributes may be derived from system application programming interfaces (APIs), network observations, or trusted execution environments.
- **Device Integrity and Attestation:** The device supports mechanisms to assert platform integrity, such as Trusted Execution Environments (TEE), secure

enclaves, or platform attestation services. These mechanisms provide evidence of the device state (e.g., non-rooted, verified boot, emulator).

- **Cryptographic Capability:** The device can securely generate and use cryptographic keys for authentication, including signing challenges and participating in hardware-backed authentication protocols (e.g., FIDO2 and, Trusted Platform Module (TPM)-based attestation).
- **Secure Communication:** All communication between the device and verifier is assumed to occur over secure channels (e.g., TLS), ensuring confidentiality and integrity of transmitted data.

7) SCOPE OF APPLICABILITY

In environments where such device capabilities are unavailable (e.g., legacy systems without attestation support), the

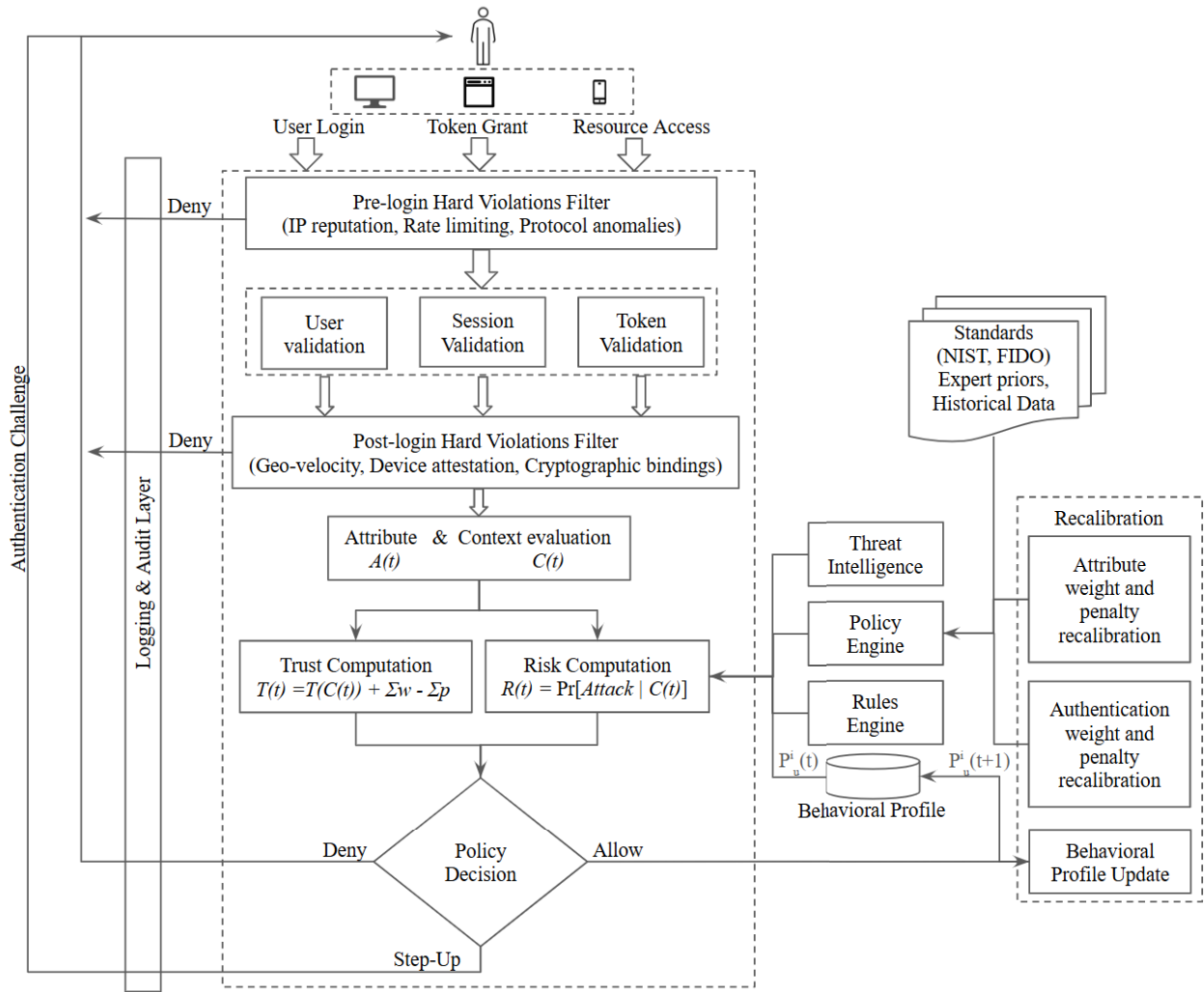


FIGURE 1. ZeTHAA system architecture.

framework degrades gracefully by assigning lower weights to untrusted attributes and relying more heavily on behavioral and contextual risk signals.

D. TRUST AND RISK

The trust state $T(t) \in [0, 1]$ represents an accumulated confidence. The trust evolves over time as the user continues to interact with the system. The trust $T(t)$ is thus a function of the current and historical context, modeled as:

$$T(t) = f(C(t), T(t^-)),$$

where $T(t^-)$ is the historical trust. Trust $T(t)$ at any time is a composite of contextual conformance, behavioral history, device postures, and risk signals.

$R(t) \in [0, 1]$ represents the security outcome at time t . $R(t) = \Pr[\text{Attack Success} \mid C(t)] = 1$ represents the risk of adversarial access.

E. SECURITY OBJECTIVE

The primary security objective of the proposed system is to ensure that access to any protected resource is granted and maintained only when the probability of adversarial success in the current context remains below an acceptable threshold.

For any session context $C(t)$ at any given time t , the system enforces:

$$\forall t, \forall k \in \mathcal{K}, \Pr(R_k(t) = 1 \mid C(t)) \leq \delta_k$$

$$R_k(t) \in \{0, 1\} \forall k \in \mathcal{K}$$

where $R_k(t) = 1$ indicates a successful attack of class k at time t . $R_k(t) = 0$ otherwise. δ represents a configurable risk tolerance.

The system adapts authentication strengths and authorization decisions to evolving risk, thereby enforcing continuous risk evaluation, consistent with Zero-Trust principles.

F. ATTRIBUTES

The system defines a set of attributes $\mathcal{A}$. An attribute a_i is a measurable contextual or behavioral property derived from the user, the device, or the application that facilitates the construction of an overall risk profile and the computation of the risk probability.

Each user request transmits a collection of attributes $a_i \in \mathcal{A}$ to the system. The set of attributes $\mathcal{A}$ and its weight $W(\mathcal{A})$ can be defined as:

$$\mathcal{A} = \{a_i \in \mathcal{A} \mid w(a_i) < T_r(R_i)\},$$

where the weight assigned to any attribute is less than the trust required to access any resource R_i .

The set of attributes $\mathcal{A}$ is extensible, and new attributes can be added as discovered.

G. AUTHENTICATION MODALITIES

The system is configured with a set of authentication modalities $\mathcal{M}$ with a corresponding set of weights $W(\mathcal{M})$. The set of authentication modalities $\mathcal{M}$ is defined as follows:

$$\mathcal{M} = \{m \in \mathcal{M} \mid w(m) < T_r(i)\}$$

where $w(m)$ is the weight assigned to a selected authentication modality $m \in \mathcal{M}$. The weight obtained by successful authentication with any participating modality will always be less than the trust required to access the resource, $T_r(R_i)$.

The set $\mathcal{M}$ is extensible and can accommodate newer authentication modalities.

With this system model established, we define user identity using authentication sessions.

H. AUTHENTICATION SESSION MODEL

The authentication $Auth_i$ is represented as:

$$Auth_i(U_i, m_i, C) \rightarrow \{True, False\}$$

where U_i represents the user requesting verification of identity, m_i denotes the authentication method applied, and context $C = C_{contextual} \cup C_{behavioral}$ denotes the context originating from behavioral and contextual signals.

An authentication session is a construct established upon successful authentication, defined as:

$$S = (U_i, m, t_0, t_e, \sigma)$$

where:

- $U_i \in U$ is the authenticated user,
- $m \in M$ is the authentication method used,
- t_0 is the authentication start time,
- t_e is the expiration time,
- $\sigma \in \{\text{active, expired, revoked}\}$ denotes the authentication state.

An authentication session only establishes the identity of a user at a given point in time. This does not imply continued authorization. While authentication sessions verify and establish user identity, authorization decisions depend on additional environmental and situational factors, which are modeled as a session context.

I. SESSION CONTEXT MODEL

The session context captures the environmental and situational conditions under which access requests are evaluated. It is defined as a time-dependent tuple:

$$C(t) = (R_s, D_p, N_s, T_c(t), L_c),$$

where:

- R_s denotes resource sensitivity,
- D_p denotes device posture,
- N_s denotes network state,
- $T_c(t)$ denotes temporal context,
- L_c denotes location context.

The session context evolves over time and directly influences risk estimation, trust computation, and authorization decisions. Given the dynamic nature of the session context, authorization must be continuously evaluated and not treated as a one-time decision.

J. ATTRIBUTE TAXONOMY AND CLASSIFICATION

An attribute a_i is a behavioral or contextual property associated with a user, device, session, or request. Attributes provide contextual signals that are relevant to dynamic risk and trust computation in Zero Trust systems. This section introduces an attribute taxonomy and classification based on their properties.

1) COMPOSITE ATTRIBUTE SET

The proposed ZeTHAA framework classifies attributes under three categories, i.e., - “User,” “Application,” and “Device,” based on the participating entities. The attributes and entities are discrete yet related. This establishes a “who uses what, where” relationship among the three discrete entities (user, device, browser/application), and this relationship model allows attribute variances to be flagged across categories. The application attributes provide a way to uniquely identify “the application, running on device” combination. Thus, the attribute-driven context becomes a composite construct of “user, using the application, on device”. The attributes used in the Composite Attribute set are listed in Table 2.

For mobile devices, the device attribute set is obtained via Application Programming Interfaces (APIs) provided by the native mobile operating system.

2) ATTRIBUTE CLASSIFICATION

Attributes are classified based on their type, stability, and applicability to context binding.

1) Contextual Vs Behavioral

Attributes that describe the execution environment are classified as contextual, and those that describe user interaction over time are considered behavioral. Table 3 classifies the attributes as contextual or behavioral.

2) Stability

Attributes can be classified as static or dynamic based on their tendency to change over time, which affects their contribution to the persistence or trust decay and

TABLE 2. Composite attribute set.

User Attributes	Application Attributes	Device Attributes
{ Id, Time of login, Request Type, IP Address, Attempts to log in, Geo-velocity, Time taken to answer challenge, Number of times blocked out, Attempts during cool-off period }	{package name, version, applicationId, build time secret, application authenticity data }	{ GPS Location, User-Agent, localization:{ language,locale, timeZone}, screenResolution:{ height, width}, details:{ model, platform, uuid, OSversion, manufacturer, isVirtual, serial }}}

TABLE 3. Contextual vs behavioral attribute classification.

Attribute	Type
Device Serial, UUID, Manufacturer	Contextual
Device Model, Platform, OS Version	Contextual
Application ID, Package Name	Contextual
Application Authenticity Data	Contextual
User-Agent, Screen Resolution	Contextual
IP Address, Geo-location, GPS Location	Contextual
Time Zone, Localization	Contextual
Time of Login	Behavioral
Attempts to Login	Behavioral
Attempts During Cool-off	Behavioral
Number of Times Blocked Out	Behavioral
Time to Answer Challenge	Behavioral
Request Type	Behavioral

their suitability for continuous validation. For instance, application and device attributes are predominantly static and do not change during their interactions with the system. Table 4 classifies attributes based on their disposition to change.

Predominantly static attributes contribute to longer-lived trust, while dynamic attributes are continuously evaluated and utilized to detect anomalies.

K. DYNAMIC ATTRIBUTE ANALYSIS AND BEHAVIORAL PROFILING

Contextual and behavioral attributes change owing to user behavior, operational changes, and modifications to the access device. For example, a login location or access time may be benign for one user while anomalous for another. As such, static interpretation of attributes is not sufficient in Zero Trust environments. In ZT systems, trust must be continuously evaluated, updated, or recalibrated.

This section introduces a dynamic analysis of observed attributes, how they contribute to user-specific profiles, and provides signals and evidence for trust, risk, and authorization decisions.

1) BEHAVIORAL AND CONTEXTUAL PROFILES

For each user u (or device, where applicable), the system maintains a behavioral and contextual profile $\mathcal{P}_u$, constructed

from benign historical observations. A profile represents the expected distribution or pattern of attribute values and may include summary statistics, temporal patterns, or learned probabilistic behavior.

For an attribute a_i , the profile $\mathcal{P}_u^i$ captures its expected behavior, modeled as:

$$\mathcal{P}_u^i = \{\mathbb{E}[a_i], \text{Var}[a_i], \dots\},$$

where $\mathbb{E}[a_i]$ represents the mean value and $\text{Var}[a_i]$ denotes the observed variance of the attribute a_i . Profiles are updated conservatively to accommodate benign drift while avoiding rapid adaptation resulting from potentially adversarial behavior.

2) DEVIATION AND ANOMALY SCORING

Behavioral patterns can change, subject to human behavior or associated changes. If a user with an established pattern of logging in at 10 A.M. daily logs in at 9 A.M., the system records this as a deviation from the established pattern. However, this does not conclusively establish risk or adversarial behavior. While the deviation indicates an elevated risk, it could be an isolated incident of a user logging in at a different time. The system records, flags, and validates deviations against tolerance limits set per policy.

At time t , the observed attribute value $a_i(t)$ is compared against the corresponding profile $\mathcal{P}_u^i$ to compute a deviation score:

$$\Delta a_i(t) = \text{dist}(a_i(t), \mathcal{P}_u^i),$$

where Δa_i represents the deviation of the observed value of the attribute from the established mean value.

Observed deviations are evaluated relative to acceptable attribute-specific variation thresholds. Let θ_i denote the permissible deviation for attribute a_i . Deviations within this tolerance are treated as benign, while excess deviation contributes to anomaly scoring and penalty assignment.

$$\Delta a_i^+(t) = \max(0, \Delta a_i(t) - \theta_i)$$

The deviation score quantifies how unusual the current observation is relative to established behavior, but does not directly result in a classification decision.

TABLE 4. Temporal disposition of attributes.

Attribute	Static	Predominantly Static	Dynamic	Justification
Device Serial	✓			Hardware-bound, immutable
UUID	✓			Persistent identifier
Application Authenticity Data	✓			Cryptographically fixed
Application ID	✓			Issuer-defined
Package Name	✓			Namespace identifier
Manufacturer		✓		Changes only with device swap
Device Model		✓		Fixed for device lifetime
Platform		✓		OS family rarely changes
OS Version		✓		Updates occur infrequently
Application Version		✓		Controlled release cycles
IsVirtual		✓		Execution environment invariant
User-Agent			✓	Easily spoofed or changed
IP Address			✓	Network mobility
Geo-location			✓	Physical movement
GPS Location			✓	Sensor-based
Screen Resolution			✓	Device and orientation changes
Time Zone			✓	Travel or configuration
Localization			✓	User preference
Time of Login			✓	Time-varying behavior
Attempts During Cool-off			✓	Attack indicator
Number of Times			✓	Accumulative behavior
Time to Answer Challenge			✓	Response variability
Request Type			✓	Action-Dependent

3) MAPPING DEVIATIONS TO ATTRIBUTE PENALTIES

Deviation scores are mapped to attribute penalties that reflect increased suspicion or reduced confidence in the observed evidence. For attribute a_i , the penalty at time t is a function of the deviation observed:

$$\pi_i(t) = g(\Delta a_i(t)),$$

where $g(\cdot)$ is a policy-defined function that controls sensitivity to deviations. Larger deviations result in higher penalties, which in turn reduce trust and increase estimated risk in subsequent computations. The penalties represent the system's *assessment* of elevated risk based on observed behavior; they do not imply that an attack has occurred.

The deviation-derived penalties introduced in this section represent instantaneous evidence of anomalous behavior. These signals are subsequently aggregated and recalibrated over time by the penalty assignment model described later, which accounts for historical observations, resource sensitivity, and policy constraints.

4) ROLE OF MACHINE LEARNING

Machine learning is employed in this layer exclusively for evidence interpretation. Machine learning is strictly limited to learning and updating behavioral profiles and computing deviation scores. It does not directly determine authentication or authorization outcomes, or modify authentication strength or policy thresholds. Instead, ML-derived outputs serve as inputs to trust, risk, and authorization decisions.

This separation enables the system to adapt to evolving user behavior and environmental conditions.

5) INTEGRATION WITH DOWNSTREAM COMPONENTS

The penalties derived through dynamic attribute analysis are incorporated into the composite trust and risk models

described in subsequent sections. Attribute penalties influence trust decay, contribute to attack success probability estimation, and trigger adaptive enforcement actions during continuous monitoring.

Thus, dynamic attribute analysis provides the foundation for threat modeling, authorization decisions, and Zero Trust guarantees.

L. BEHAVIORAL PROFILE CONSTRUCTION AND EVOLUTION

This section formalizes the construction and evolution of behavioral profiles introduced earlier. Behavioral profiles capture long-term patterns of user behavior and serve as the reference against which deviations are evaluated for penalty assignment and trust computation. The framework design balances adaptability to legitimate behavioral drift with resistance to profile poisoning.

1) PROFILE INITIALIZATION

For each user u and behavioral attribute a_i , an initial profile $\mathcal{P}_u^i(t_0)$ is established at the first trusted observation. The profile maintains summary statistics (mean and variance) representing normal behavior.

This initialization phase provides a stable baseline from which learning can proceed cautiously as observations accumulate. Algorithm 1 details the initialization of the behavioral profile.

2) HARD AND SOFT CONTEXTUAL VIOLATIONS

Observed deviations from behavioral profiles are classified as either *hard* or *soft* violations.

Hard violations correspond to physically or logically impossible states (e.g., infeasible geo-velocity, cryptographic binding failures, token replay, hardware attestation failure,

Algorithm 1 Behavioral Profile Initialization**Require:** Attribute a_i , initial observation $a_i(t_0)$ **Require:** Default variance σ_0^2 , learning rate γ **Ensure:** Initialized behavioral profile $\mathcal{P}_u^i$

- 1: Initialize mean: $\mu_i \leftarrow a_i(t_0)$
- 2: Initialize variance: $\sigma_i^2 \leftarrow \sigma_0^2$
- 3: Set profile $\mathcal{P}_u^i \leftarrow \{\mu_i, \sigma_i^2\}$
- 4: Initialize penalty accumulator $\Pi_i \leftarrow 0$

application signature mismatch). Such violations indicate session compromise with high confidence and result in immediate access denial or session termination. Hard violations permanently disable learning for the affected session. Let $HV(t) \in \{0, 1\}$ denote the hard violation predicate at time t , where $HV(t) = 1$ indicates that at least one hard violation has occurred within the current authentication or access session. Once a hard violation occurs, trust- and risk-based reasoning is no longer valid, and the session must be terminated or re-authenticated. The hard violation check is used by the system as a primary defensive validation for each request, enabling it to reject any request that violates the condition immediately.

Soft violations correspond to statistically unlikely but plausible behavioral deviations (e.g., unusual login time, new location). These violations incur penalties that reduce trust but do not immediately invalidate the session. Soft violations temporarily suspend learning until trust is re-established.

Table 5 classifies contextual signals into hard and soft violations with the corresponding action executed by the system.

Global Admissibility Predicate

The system defines a global admissibility predicate:

$$\text{Admissible}(t) \iff (HV(t) = 0)$$

The admissibility predicate represents a system-wide safety invariant. All authentication, authorization, token issuance, and resource access events are defined only over an admissible system state. If $\text{Admissible}(t) = 0$, all subsequent requests are denied irrespective of accumulated trust, authentication strength, or contextual evidence.

This separation ensures that trust computation operates strictly within safe execution states, while hard violations trigger immediate and deterministic security responses. This distinction allows the system to react decisively to impossible states while remaining tolerant of legitimate behavioral variation.

3) BEHAVIORAL LEARNING POLICY

Behavioral profiles are updated in an event-driven and trust-based manner. Profile updates occur only when no hard violations are observed, the current trust level exceeds a learning threshold, authentication strength is satisfactory, and no significant penalties are present. This approach ensures that anomalous behavior does not contribute to profile learning and adaptation. The learning condition is modeled

as:

$$\begin{aligned} \text{Learn}(t) = \text{Trust}(t) \geq \tau_{\text{learn}} \\ \wedge \Pi_i(t) \leq \epsilon \wedge S(m) \geq S_{\text{learn}} \\ \wedge \neg \text{HardViolation}(t) \end{aligned} \quad (1)$$

where τ_{learn} is a minimum trust threshold, $\Pi_i(t)$ represents the cumulative penalties at time t , ϵ is a small penalty tolerance, $S(m)$ is the current authentication strength, S_{learn} is a minimum authentication assurance required for learning, and no hard violations have been observed. In addition, a state variable $\text{LearningEnabled}(t)$ governs whether profile updates are allowed, transitioning to false upon anomalous events, and returning to true only when sufficient trust has been built, and soft violations remain within acceptable bounds. The behavioral profile update proceeds only if:

$$\text{UpdateAllowed}(t) = \text{Learn}(t) \wedge \text{LearningEnabled}(t)$$

When $\text{Learn}(t) = 1$, the profile is updated using an exponentially weighted moving average (EWMA):

$$\mathcal{P}_u^i(t+1) = (1-\gamma)\mathcal{P}_u^i(t) + \gamma a_i(t), \quad \gamma \in (0, 1), \gamma \ll 1. \quad (2)$$

If $\text{Learn}(t) = 0$, then $\mathcal{P}_u^i(t+1) = \mathcal{P}_u^i(t)$.

This separation ensures immediate reaction to suspicious behavior while allowing learning to resume only after sustained trust is re-established.

4) LEARNING SUSPENSION AND RE-ENABLEMENT

To prevent adversarial manipulation, learning is suspended whenever anomalous behavior is observed and the state variable $\text{LearningEnabled}(t)$ transitions to false.

However, suspending learning indefinitely would prevent adaptation to legitimate behavioral shifts. Therefore, learning is re-enabled only after sustained evidence of legitimacy is observed over a temporal window W :

$$\begin{aligned} \text{ReLearn}(t) = \frac{1}{|W|} \sum_{s \in W} \text{Trust}(s) \geq \tau_{\text{learn}} \\ \wedge \sum_{s \in W} \text{Indicator}(\Pi_i(s) > 0) \leq k, \end{aligned} \quad (3)$$

where s is a time index and k is the upper limit of the number of soft violation events permitted within the relearning window W , and $\text{Indicator}(\cdot)$ is an indicator function.

When $\text{ReLearn}(t) = \text{true}$, LearningEnabled transitions to true.

5) BEHAVIORAL LEARNING STRATEGIES

Once initialized, behavioral profiles evolve through controlled learning. Different attributes exhibit varying observation frequencies and noise characteristics; therefore, a single learning mechanism is insufficient. Accordingly, each attribute a_i is assigned a learning strategy $\chi_i \in \{\text{online}, \text{windowed}\}$ based on its volatility, observation frequency, and security sensitivity.

TABLE 5. Hard violations vs soft contextual signals.

Signal Type	Examples	System Action
Hard Violations	Impossible travel, application signature mismatch, token binding mismatch, replayed token	Immediate deny or token revocation
Soft Signals	Login time deviation, geo drift, device change, authentication failures	Penalty $\rightarrow$ trust decay $\rightarrow$ adaptive enforcement

The system responds faster to behavioral attributes with natural drift, to ensure faster adaptation and prevent step-up authentication in every request. Stable and security-sensitive attributes present a very slow rate of change. Sudden changes to these attributes could signify an attempt at repeated attacks or profile poisoning by adversarial elements. As such, stable and security-sensitive attributes are assigned a slow learning and adaptation rate.

The system defines a learning rate γ_i that controls the speed at which the behavioral profile adapts to new observations. These values are policy-configurable and serve as conservative defaults for evaluation. This hybrid strategy ensures responsiveness to legitimate behavioral drift while improving robustness against noise and profile poisoning.

$\gamma_i \downarrow$ for stable/contextual attributes,

$\gamma_i \uparrow$ for behavioral attributes with natural drift.

Furthermore, profile updates are calculated using EWMA to ensure that profiles respond immediately to changes, adapt gradually to legitimate behavioral drift, maintain historical precedents, and give new observations more weightage in the profile.

Behavioral profile updates are performed at two levels of granularity. Trust-based online updates apply to low-frequency, low-noise attributes, enabling immediate but conservative adaptation. For high-frequency or noisy attributes, updates are performed over trusted observation windows, allowing learning from aggregate behavior while improving stability and resistance to profile poisoning.

a: TRUST-GATED ONLINE UPDATE

For stable, low-noise behavioral attributes (e.g., login time), profile updates are performed using trust-gated online learning. When learning is permitted, the profile mean is updated using EWMA:

$$\mu_i(t+1) = (1 - \gamma_i)\mu_i(t) + \gamma_i a_i(t),$$

where $0 < \gamma_i \ll 1$ is the attribute-specific learning rate. Online updates enable gradual adaptation from individual trusted observations while restricting the influence of any single event.

Algorithm 2 demonstrates the trust-gated online behavioral profile update.

b: WINDOWED BEHAVIORAL UPDATE

For high-frequency or noisy attributes (e.g., IP address, access patterns), learning is performed over trusted observation windows. Let $W_i = \{t_1, \dots, t_{|W_i|}\}$ denote a window of

Algorithm 2 Trust-Gated Online Behavioral Profile Update

Require: Current observation $a_i(t)$
Require: Current profile $\mathcal{P}_u^i(t) = \{\mu_i(t), \sigma_i^2(t)\}$
Require: Trust $\text{Trust}(t)$, penalty $\Pi_i(t)$
Require: Thresholds $\tau_{\text{learn}}, \epsilon$
Require: Learning rate γ
Ensure: Updated profile $\mathcal{P}_u^i(t+1)$
1: **if** $\text{Trust}(t) < \tau_{\text{learn}}$ **or** $\Pi_i(t) > \epsilon$ **then**
2: $\mathcal{P}_u^i(t+1) \leftarrow \mathcal{P}_u^i(t)$
3: **return**
4: **end if**
5: Update mean (EWMA):
6: $\mu_i(t+1) \leftarrow (1 - \gamma)\mu_i(t) + \gamma a_i(t)$
7: Update variance:
8: $\sigma_i^2(t+1) \leftarrow (1 - \gamma)\sigma_i^2(t) + \gamma(a_i(t) - \mu_i(t))^2$
9: $\mathcal{P}_u^i(t+1) \leftarrow \{\mu_i(t+1), \sigma_i^2(t+1)\}$

observations. The aggregated behavior is computed as:

$$\bar{a}_i(W_i) = \frac{1}{|W_i|} \sum_{t \in W_i} a_i(t). \quad (4)$$

Profile updates are then applied using EWMA:

$$\mu_i(t+1) = (1 - \gamma_i)\mu_i(t) + \gamma_i \bar{a}_i(W_i).$$

Windowed updates reduce sensitivity to transient noise and improve robustness against in-session profile poisoning. Algorithm 3 presents the windowed approach to behavioral profile update for high-frequency attributes.

Algorithm 3 Windowed Behavioral Profile Update

Require: Observation window $W = \{a_i(t_1), \dots, a_i(t_k)\}$
Require: Window trust summary $\overline{\text{Trust}}(W)$
Require: Window penalty indicator $\Pi_i(W)$
Require: Profile $\mathcal{P}_u^i(t)$
Require: Learning parameters $\tau_{\text{learn}}, \gamma$
Ensure: Updated profile $\mathcal{P}_u^i(t+1)$
1: **if** $\overline{\text{Trust}}(W) < \tau_{\text{learn}}$ **or** $\Pi_i(W) > 0$ **then**
2: $\mathcal{P}_u^i(t+1) \leftarrow \mathcal{P}_u^i(t)$
3: **return**
4: **end if**
5: Compute window aggregate:
6: $\bar{a}_i \leftarrow \frac{1}{|W|} \sum_{t \in W} a_i(t)$
7: Update mean:
8: $\mu_i(t+1) \leftarrow (1 - \gamma)\mu_i(t) + \gamma \bar{a}_i$
9: $\mathcal{P}_u^i(t+1) \leftarrow \{\mu_i(t+1), \sigma_i^2(t)\}$

Together, these strategies define *how* behavioral profiles are updated, as attributes are observed and evaluated.

M. AUTHENTICATION AND TRUST INITIALIZATION EVENT

An authentication session begins with an authentication and trust initialization event, which establishes the initial trust state of a user–device pair prior to any authorization decision. This event marks the transition from an unauthenticated request to an authenticated session and provides the baseline trust from which subsequent authorization, continuous monitoring, and adaptive enforcement operate. Authentication is modeled as an iterative process that may include retries and step-up challenges before a stable trust state is achieved.

1) AUTHENTICATION EVENT

Let $E_{\text{auth}}(t)$ denote an authentication event at time t , defined as:

$$E_{\text{auth}}(t) = (U, m, C(t), t),$$

where U is the user identity, m is the authentication method employed, and $C(t)$ is the contextual state observed at authentication time.

$\text{AuthSuccess}(t) \in \{0, 1\}$ denotes the outcome of the authentication attempt. Authentication succeeds if and only if $\text{Admissible}(t)=1$ and the system validates method m according to its defined assurance requirements.

2) INITIAL TRUST ASSIGNMENT

Upon successful authentication, an initial trust value is assigned:

$$\text{Trust}(t_0) = \mathcal{T}_{\text{init}}(S(m), C(t_0), \mathcal{H}(t_0)),$$

where $\mathcal{T}_{\text{init}}(\cdot)$ is a policy-defined function of the authentication strength $S(m)$, the observed authentication-time context, and behavioral history. This initial trust reflects the assurance obtained during the authentication phase, along with contextual and historical behavioral evidence.

Authentication and trust initialization are complete when:

$$\text{Admissible}(t) = 1 \quad \wedge \quad \text{Trust}(t) \geq \tau_{\text{auth}}.$$

The resulting trust value $\text{Trust}(t_0)$ forms the baseline for subsequent authorization decisions and continuous monitoring.

3) AUTHENTICATION ATTEMPT AND RETRY SEMANTICS

Authentication attempts may succeed or fail due to benign user error (e.g., mistyped credentials). Such failures are treated as soft violations and result in a reduction in trust rather than immediate termination. Authentication retries are re-evaluated under ZT principles, in which each retry is treated as an independent request with a fresh contextual and behavioral assessment.

Let $E_{\text{auth}}^{(k)}(t)$ denote the k -th authentication attempt within a session at time t .

Trust is updated as:

$$\text{Trust}(t+1) = \text{Trust}(t) + w_m \cdot (\text{AuthSuccess}(t)) - \pi_m \cdot (1 - \text{AuthSuccess}(t)), \quad (5)$$

where w_m is the positive contribution of authentication method m , and π_m is the penalty applied upon failure.

4) STEP-UP AUTHENTICATION TRIGGER

Repeated failures or low resulting trust may trigger additional authentication factors. Step-up authentication is required when:

$$\text{Trust}(t) < \tau_{\text{step-up}},$$

where $\tau_{\text{step-up}}$ is a policy-defined threshold. Step-up mechanisms may include OTP, hardware-backed challenge, or additional verification factors.

5) RETRY CONSISTENCY AND TRUST DELTA ANALYSIS

Let k denote the retry index within the current authentication session. The trust value at retry k is defined as:

$$\text{Trust}_k = f(C_k, m_k, \mathcal{H}_{k-1}),$$

where C_k represents the contextual state at retry k , m_k is the authentication method employed, and $\mathcal{H}_{k-1}$ denotes the prior retry history.

The trust delta between successive retries is modeled as:

$$\Delta T_k = \text{Trust}_k - \text{Trust}_{k-1}. \quad (6)$$

In a Zero-Trust system, contextual drift, device change (e.g., logging in from a different device), or network variation (e.g., turning on VPN) may legitimately reduce trust even when authentication succeeds. The system can verify trust fluctuation between attempts, based on a policy-defined threshold $\epsilon_T > 0$, such that:

$$\Delta T_k < -\epsilon_T$$

to determine and record the possibility of brute force attacks, credential misuse, automation, or adversarial replay. The authentication and trust initialization event defines the starting state for continuous verification under the Zero Trust model. Algorithm 4 defines the authentication and trust initialization event.

6) HARD VIOLATION ESCALATION

Authentication failure alone does not constitute a hard violation. However, excessive failures or detection of adversarial patterns (e.g., brute force attacks, credential stuffing, automation, or cryptographic proof failure) result in:

$$\text{HV}(t) \leftarrow 1.$$

Once $\text{HV}(t) = 1$, the system becomes non-admissible and the session is terminated.

Algorithm 4 Authentication With Retry and Trust Initialization

```

1: procedure Authenticate( $U, m, C(t)$ )
2:    $attempts \leftarrow 0$ 
3:    $Trust(t) \leftarrow 0$ 
4:   while  $attempts < N_{max}$  do
5:     if  $Admissible(t) = 0$  then
6:       return Reject
7:     end if
8:      $result \leftarrow VerifyAuthMethod(U, m)$ 
9:     if  $result = success$  then
10:       $Trust(t) \leftarrow Trust(t) + w_m$ 
11:    else
12:       $Trust(t) \leftarrow Trust(t) - \pi_m$ 
13:       $attempts \leftarrow attempts + 1$ 
14:    end if
15:    if  $Trust(t) < \tau_{step-up}$  then
16:       $TriggerStepUp(U)$ 
17:       $stepResult \leftarrow VerifyStepUp(U)$ 
18:      if  $stepResult = failure$  then
19:         $HV(t) \leftarrow DetectHardAttack(U)$ 
20:        if  $HV(t) = 1$  then
21:          return Terminate Session
22:        end if
23:      else
24:         $Trust(t) \leftarrow Trust(t) + w_{step}$ 
25:      end if
26:    end if
27:    if  $Trust(t) \geq \tau_{auth}$  then
28:      return Authenticated
29:    end if
30:  end while
31:   $HV(t) \leftarrow 1$ 
32:  return Lock or Escalate
33: end procedure

```

7) SEPARATION FROM AUTHORIZATION

The trust initialized at authentication time serves as an input to authorization decisions but does not itself imply access to any protected resource. Authorization is evaluated independently based on resource sensitivity, required assurance levels, and contextual risk. This separation ensures that authentication establishes identity and baseline confidence, while authorization enforces ZT prescribed least-privilege access under continuous evaluation. We now model the post-login authorization and subsequent flows in the next section.

N. AUTHORIZATION DECISION AND EVENT

An authorization event is defined as:

$$\mathcal{E}_a(t) = (U_i, R_i, \mathcal{A}(t), t)$$

where U_i is the user, R_i is the requested resource, $\mathcal{A}(t)$ is the authorization decision and t is the decision timestamp.

Algorithm 5 Authorization Decision Evaluation

Require: Resource R_s , context $C(t)$, authentication state $S(t)$

Ensure: Authorization decision

```

1: if  $\neg AuthValid(S(t))$  then
2:   return Deny
3: end if
4: if  $\hat{S}_{eff}(m, t) < \hat{S}_{req}(C(t), R_s)$  then
5:   return Step-Up Authentication
6: end if
7: if  $Trust(C(t)) < \tau_{grant}(R_s)$  then
8:   return Deny
9: end if
10: if  $Pr[Attack\ Success \mid C(t)] > \delta_{grant}(R_s)$  then
11:   return Deny
12: end if
13: return Authorize

```

Authorization is granted if and only if:

$$AuthValid(S(t)) \wedge ContextAcceptable(C(t)) \wedge (T(t) \geq T_r(R_i))$$

where $T_r(R_i)$ is the trust required to access R_i based on the specified policy $Policy_{R_i}$ on the resource.

Authorization decisions are evaluated continuously over time. The authorization decision at time t is modeled as:

$$\mathcal{A}(t) = f(S(t), C(t), T(t), R_s),$$

where $S(t)$ denotes the authentication state, $C(t)$ the session context, and $T(t)$ the trust gained.

Let $\mathcal{R}(t) = Pr[Attack\ Success \mid C(t)]$ denote the composite risk evaluated under session context $C(t)$. Each protected resource R_i is associated with two risk thresholds $\delta_1(R_i)$ and $\delta_2(R_i)$ such that:

$$0 < \delta_1(R_i) < \delta_2(R_i) < 1.$$

The authorization decision at time t is defined as the following threshold-based function:

$$\mathcal{A}(t) = \begin{cases} \text{allow,} & \text{if } \mathcal{R}(t) \leq \delta_1(R_i), \\ \text{step_up,} & \text{if } \delta_1(R_i) < \mathcal{R}(t) \leq \delta_2(R_i), \\ \text{deny,} & \text{if } \mathcal{R}(t) > \delta_2(R_i). \end{cases} \quad (7)$$

This ensures that increasing risk enforces stricter actions to protect the system. Authorization decisions thus become continuous verification consistent with Zero-Trust principles. Algorithm 5 defines the evaluation of the authorization decision.

The issuance and use of authorization tokens that mediate access to protected resources following an authorization decision are modeled in the following section.

Algorithm 6 Authorization Token Grant**Require:** Authorization decision, context $C(t)$, resource R_s **Ensure:** Token T or denial

```

1: if Authorization decision  $\neq$  Authorize then
2:   return No Token Issued
3: end if
4: Bind token to context:  $T \leftarrow \text{Bind}(u, R_s, C(t), t)$ 
5: Set token validity window and scope
6: Log authorization grant event  $E_g(t)$ 
7: return Token  $T$ 

```

O. AUTHORIZATION GRANT AND TOKEN-BASED RESOURCE ACCESS

In Zero-Trust systems, authentication alone does not grant access to protected resources. Instead, successful authentication enables an explicit authorization grant, typically realized through short-lived authorization tokens (e.g., OAuth access tokens, Security Assertion Markup Language (SAML) assertions, or JSON Web Tokens (JWT)).

1) AUTHORIZATION TOKEN MODEL

Authorization tokens are security artifacts distinct from authentication sessions. An authorization token is modeled as:

$$\mathcal{T} = (U_i, s, \ell, \tau_e, \kappa)$$

where:

- $U_i \in U$ denotes the user,
- s denotes the associated authentication session identifier,
- ℓ denotes the authorized scope or privileges,
- τ_e denotes the token expiration time,
- κ denotes cryptographic or contextual binding.

2) AUTHORIZATION GRANT EVENT

An authorization grant event is defined as:

$$\mathcal{E}_g(t) = (S(t), C(t), \mathcal{T}, t)$$

An authorization token is issued if and only if:

$$\begin{aligned} & \text{AuthValid}(S(t)) \wedge S(m) \geq S_{\text{req}}(C(t)) \wedge \\ & \text{Pr}[\text{Attack Success} \mid C(t)] \leq \delta_{\text{grant}}(R_s) \\ & \wedge (T(t) \geq T_{\text{grant}}(R_s)) \end{aligned} \quad (8)$$

where $S(m)$ denotes authentication strength, $T_{\text{grant}}(R_s)$ is the minimum trust threshold, and $\delta_{\text{grant}}(R_s)$ is the maximum acceptable attack success probability.

This ensures that possession of valid credentials alone is insufficient to obtain authorization artifacts. Algorithm 6 describes the authorization token grant flow.

3) RESOURCE ACCESS USING AUTHORIZATION TOKENS

A resource access request at time t is defined as:

$$\mathcal{E}_r(t) = (U_i, R_i, \mathcal{T}, C(t))$$

Algorithm 7 Resource Access Enforcement**Require:** Access request (T, R_s) , current context $C(t)$ **Ensure:** Access decision

```

1: if  $\neg \text{ValidateToken}(T)$  then
2:   return Deny Access
3: end if
4: if  $\neg \text{ContextMatch}(T, C(t))$  then
5:   Apply token-context mismatch penalty
6:   return Deny Access
7: end if
8: if  $\text{Trust}(C(t)) < \tau_{\text{access}}(R_s)$  then
9:   return Re-authentication Required
10: end if
11: if  $\text{Pr}[\text{Attack Success} \mid C(t)] > \delta_{\text{access}}(R_s)$  then
12:   return Deny Access
13: end if
14: return Grant Access

```

Token validity is defined as:

$$\begin{aligned} & \text{TokenValid}(\mathcal{T}, C(t)) \\ & = 1 \left(t < \tau_e \wedge \text{Bind}(\mathcal{T}, C(t)) \wedge \text{ScopeAllowed}(\ell, r) \right) \end{aligned} \quad (9)$$

Resource access is granted if and only if:

$$\begin{aligned} & \text{AuthValid}(S(t)) \wedge \text{TokenValid}(\mathcal{T}, C(t)) \wedge \\ & \text{Pr}[\text{Attack Success} \mid C(t)] \leq \delta_r(R_s) \end{aligned} \quad (10)$$

This formulation enforces continuous authorization even in the presence of valid tokens.

P. CONTINUOUS MONITORING AND RE-EVALUATION

As a Zero-Trust system, the context, risk, and trust states must be continuously evaluated, and authorization decisions should be revalidated throughout the lifetime of a session. The system enters a continuous monitoring and re-evaluation phase following the authorization grant and token issue. This phase spans the lifetime of the session.

The continuous monitoring function at time t is modeled as:

$$\mathcal{M}(t) : (C(t), T(t^-), R(t^-), \mathcal{T}_t) \rightarrow (T(t), R(t), \mathcal{E}(t)),$$

where

- $C(t)$: current context
- $T(t^-), T(t)$: past and current trust states
- $R(t^-), R(t)$: past and current risk states
- $\mathcal{T}_t$: current and active token
- $\mathcal{E}(t)$: enforcement decision

Algorithm 8 represents the continuous monitoring and re-evaluation flow.

1) TRUST UPDATE

Trust evolves as a function of prior trust, current context, and estimated risk.

Algorithm 8 Continuous Monitoring and Re-Evaluation**Require:** Active session, context stream $C(t)$ **Ensure:** Updated trust, enforcement actions

```

1: while Session Active do
2:   Observe new attributes and events
3:   Update context  $C(t)$ 
4:   Update attribute penalties for mismatch or absence
5:   Update authentication penalties if applicable
6:   Recompute  $\text{Trust}(C(t))$ ,  $\text{Pr}[\text{Attack Success} \mid C(t)]$ 
7:   if Any authorization threshold violated then
8:     Enforce step-up authentication, token revocation,
      or termination
9:   end if
10: end while

```

The current context can be modeled as:

$$\begin{aligned}
C(t) = & \lambda^+ \sum_{a_i \in A} w_i \cdot \text{Indicator}(a_i) \cdot [\text{match}(a_i(t))] \\
& - \sum_{a_i \in A} \left(\lambda_i^{\text{mm}}(R_s) \cdot \pi_i \cdot \text{Indicator}(a_i) \cdot [\text{mismatch}(a_i(t))] \right. \\
& \left. + \lambda_i^{\text{miss}}(R_s) \cdot \pi_i^{\text{miss}} \cdot \text{Indicator}(a_i) \cdot [\text{missing}(a_i(t))] \right) \quad (11)
\end{aligned}$$

where:

- $\lambda^+ \in (0, 1)$ denotes the rate at which trust increases in response to a matching contextual attribute a_i .
- w_i denotes the positive weight associated with an attribute a_i .
- $\lambda_i^{\text{mm}} \in (0, 1]$ denotes a mismatch coefficient for attribute a_i . It controls how rapidly trust decreases when the observed value of a_i deviates from expected behavior.
- $\lambda_i^{\text{miss}} \in (0, 1]$ denotes the missing-attribute coefficient for attribute a_i . It governs the rate of trust reduction when evidence for a_i is unavailable.
- $\pi_i > 0$ denotes the *penalty* associated with a mismatch of attribute a_i .
- $\pi_i^{\text{miss}} > 0$ denotes the *penalty* associated with a missing attribute a_i . This value may differ from π_i to reflect scenarios where the absence of evidence is more or less suspicious than an explicit mismatch.

$$\text{Indicator}(x) = \begin{cases} 1 & \text{if } x \text{ is present} \\ 0 & \text{if } x \text{ is absent} \end{cases}$$

Using (11), the current trust can be modeled as:

$$T(t) = (1 - \lambda^+) T(t^-) + \lambda^+ \cdot C(t) - \gamma R(t) \quad (12)$$

Here, $R(t) = \text{Pr}[\text{Attack Success} \mid C(t)]$ denotes the risk at time t based on the current context and $\gamma > 0$ represents the coefficient of risk, indicating how fast it suppresses trust.

2) TRUST DECAY

Trust is designed to decay even in the absence of user actions or reinforcing evidence. Trust decay is modeled as:

$$T(t) = T(t^-) * e^{-\mu \Delta t}, \quad (13)$$

where $\Delta t = t - t^-$, the time that elapsed between the past trust state and current trust state, ensuring that stale sessions do not retain implicit trust.

The risk $R(t)$ is, however, always fully recomputed and does not decay.

3) BINDING VALIDATION

For attributes bound to the authorization token, continuous monitoring verifies that bound attributes remain within defined tolerance thresholds. Violations contribute to increased risk and accelerated trust decay, mitigating replay and session hijacking attacks.

4) RE-EVALUATION AND ENFORCEMENT

Authorization validity is re-evaluated at each monitoring step according to:

$$\text{Reeval}(t) = \begin{cases} \text{Allow,} & T(t) \geq \tau_{\text{allow}} \wedge R(t) \leq \delta_{\text{risk}}, \\ \text{Step-Up,} & \tau_{\text{deny}} \leq T(t) < \tau_{\text{allow}}, \\ \text{Revoke,} & T(t) < \tau_{\text{deny}} \vee R(t) > \delta_{\text{risk}} \end{cases} \quad (14)$$

This formulation ensures that authorization and access privileges are continuously evaluated and adaptively enforced in response to the evolving context and threat conditions.

Having defined the authentication and authorization mechanisms, the adversarial threats to the system are modeled in the next section.

Q. THREAT MODEL

1) ADVERSARY DEFINITION

A polynomial-time adversary is modeled as:

$$\mathcal{A} = (\mathcal{K}, \mathcal{C}, \mathcal{G})$$

where $\mathcal{K}$ denotes attacker knowledge, $\mathcal{C}$ attacker capabilities, and $\mathcal{G}$ the objective of unauthorized access.

The knowledge and capability of the adversary can fall under different attack classes, such as, but not limited to:

$$\mathcal{K} = \{k_{\text{auth}}, k_{\text{grant}}, k_{\text{replay}}, k_{\text{hijack}}, k_{\text{priv}}, \dots\},$$

where:

k_{auth} : Authentication compromise

k_{grant} : Illicit authorization grant

k_{replay} : Authorization token replay

k_{hijack} : Session hijack

k_{priv} : Privilege escalation

2) ATTRIBUTE-LEVEL THREATS

Each contextual attribute $a_i \in A$ is characterized by:

$$a_i = (E_i, S_i, D_i, \rho_i)$$

where E_i denotes entropy, S_i spoofability, D_i temporal stability, and $\rho_i = \Pr(R = 1 \mid a_i)$, represents the probability of attack given a_i .

Attribute-level risk is defined as:

$$\text{Risk}(a_i) = \lambda_1(1 - E_i) + \lambda_2 S_i + \lambda_3 \rho_i$$

The probability of an adversary spoofing an attribute a_i can be defined as:

$$\Pr[\text{Forge}(a_i) \mid C] \in [0, 1]$$

The effective attribute compromise probability can be defined as:

$$\Pr[\text{Forge}(A) \mid C] = \prod_{i=1}^n \Pr[\text{Forge}(a_i) \mid C]$$

3) AUTHENTICATION METHOD THREATS

Each authentication method $m \in M$ is represented as:

$$m = (S(m), \text{Rel}(m), \text{PR}(m))$$

where $S(m)$ denotes strength, $\text{Rel}(m)$ reliability, and $\text{PR}(m)$ phishing resistance.

The probability of compromise of an authentication method m is approximated as:

$$\Pr[\text{Break}(m)] = e^{-S(m)}(1 - \text{PR}(m))$$

The effective probability of an adversary breaking an authentication method, given a surrounding context C , can be modeled as:

$$\Pr[\text{Break}(m) \mid C] = \Pr[\text{Break}(m)] \cdot (1 + \eta \cdot \text{Risk}(C)),$$

where η defines the sensitivity of the method m to contextual risk $\text{Risk}(C)$.

4) SESSION HIJACKING AND TOKEN REPLAY

A session hijacking or token replay event is modeled as:

$$\mathcal{E}_r(t) = (U'_i, R_i, T', C(t))$$

where U'_i may differ from the original authenticated user U_i , capturing session hijacking or token theft scenarios.

Token replay attacks are modeled as:

$$\exists T' \neq T \quad \text{s.t.} \quad \text{TokenValid}(T', C(t)) = 1$$

The probability of replay success is approximated as:

$$\Pr[\text{Replay Success}] = \Pr[\text{Steal}(T)] \cdot \Pr[\text{Bind Fail}(T, C(t))]$$

Session hijacking is defined as:

$$U'_i \neq U_i \wedge T' = T$$

Both attacks are mitigated through contextual binding, continuous authorization, and adaptive trust degradation.

5) PROFILE POISONING

Since the proposed framework incorporates adaptive behavioral profiling, an adversary may attempt to manipulate learned baselines by injecting malicious or atypical behavior over time, aiming to redefine normal context and reduce anomaly sensitivity.

6) COMPOSITE THREAT SURFACE

The composite threat surface is defined as the probability of unauthorized access under session context $C(t)$, accounting for attacks during both authentication and authorization phases.

a: AUTHENTICATION-PHASE ATTACK

The probability of a successful authentication-phase attack is defined as:

$$\begin{aligned} \Pr[\text{Attack}_{\text{auth}} \mid C(t)] &= 1 - (1 - \Pr[\text{Break}(m) \mid C(t)]) \cdot \\ &\quad \prod_{a_i \in C(t)} (1 - \Pr[\text{Forge}(a_i) \mid C(t)]), \end{aligned} \quad (15)$$

where $\Pr[\text{Break}(m) \mid C(t)]$ denotes the probability of compromising the active authentication method m and $\Pr[\text{Forge}(a_i) \mid C(t)]$ captures the forgeability of contextual attributes used during authentication.

If multiple authentication methods are used during the life of a session, then (15) can be modified as:

$$\begin{aligned} \Pr[\text{Attack}_{\text{auth}} \mid C(t)] &= 1 - \prod_{m \in M(t)} (1 - \Pr[\text{Break}(m) \mid C(t)]) \cdot \\ &\quad \prod_{a_i \in C(t)} (1 - \Pr[\text{Forge}(a_i) \mid C(t)]) \end{aligned}$$

b: AUTHORIZATION-PHASE ATTACK

In a Zero-Trust system, contextual attributes are validated after authentication through authorization and continuous access checks. Let $A_b \subseteq A$ denote the subset of attributes bound to the authorization token or session.

The authorization-phase attack probability is defined as:

$$\begin{aligned} \Pr[\text{Attack}_{\text{authz}} \mid C(t)] &= \Pr[\text{Illicit Grant}] \\ &\quad + \Pr[\text{Replay}] \cdot \prod_{a_i \in A_b} \Pr[\text{Forge}(a_i) \mid C(t)] \\ &\quad + \Pr[\text{Hijack}] \cdot \prod_{a_i \in A_b} \Pr[\text{Forge}(a_i) \mid C(t)]. \end{aligned} \quad (16)$$

c: UNIFIED ATTACK SUCCESS PROBABILITY

Combining (15) and (16), the overall probability of unauthorized access is defined as:

$$\begin{aligned} \Pr[\text{Attack Success} \mid C(t)] &= 1 - (1 - \Pr[\text{Attack}_{\text{auth}} \mid C(t)])(1 - \Pr[\text{Attack}_{\text{authz}} \mid C(t)]) \end{aligned}$$

R. ATTRIBUTE WEIGHT AND PENALTY ASSIGNMENT MODEL

This section formalizes the computation, initialization, and online adaptation of attribute weights and penalties used in trust evaluation. Weights are derived from threat-related properties and are computed periodically, ensuring continuous validation.

1) ATTRIBUTE UTILITY AND WEIGHT FORMULATION

a: ATTRIBUTE UTILITY

Let $A = \{a_1, a_2, \dots, a_n\}$ denote the set of attributes. Each attribute a_i is characterized by the following properties:

- $E_i \in [0, 1]$: entropy (uniqueness),
- $S_i \in [0, 1]$: spoofability,
- $D_i \in [0, 1]$: temporal stability,
- $\rho_i \in [0, 1]$: risk correlation, where $\rho_i = \Pr(R = 1 \mid a_i)$ denotes the probability of an attack.

Here, ρ_i follows a Beta distribution, $\rho_i \sim \text{Beta}(\alpha_i, \beta_i)$, where α_i and β_i denote the count of attack and benign observations, respectively. The Beta distribution model allows incremental learning and refining the attack correlation as data builds. Spoofability and stability properties of an attribute are treated as structural properties that remain constant over time. They are re-evaluated as attack vectors evolve.

Each attribute is associated with a normalized attribute utility score as a function of its properties:

$$\theta_i = U(a_i) = \alpha_E E_i + \alpha_D D_i + \alpha_\rho (1 - \rho_i) - \alpha_S S_i \quad (17)$$

where $\alpha_E, \alpha_D, \alpha_\rho, \alpha_S \geq 0$ and:

$$\alpha_E + \alpha_D + \alpha_\rho + \alpha_S = 1$$

b: COMPUTATION OF ATTRIBUTE WEIGHTS

Attribute weights are obtained using softmax normalization:

$$w_i = \frac{e^{\beta \theta_i}}{\sum_{j=1}^n e^{\beta \theta_j}} \quad (18)$$

where $\beta > 0$ determines how a difference in the attribute's utility affects the weight derivation of the attribute.

By construction:

$$\sum_{i=1}^n w_i = 1$$

The softmax normalization is utilized to ensure that strong attributes (high entropy, low spoofability) contribute more to trust gain than weak attributes. This ensures that even if the adversary manages to spoof weak attributes, the contribution to trust will be minimal.

Depending on the sensitivity of the resources, attribute weights can be modified based on the phase in which they are participating (authentication, authorization, token grant, resource access). The parameter β can be modified to be a phase-specific version β_p such that the weight becomes

a phase-specific version $w_i(p)$. Phase-specific weights allow factoring in resource sensitivity at each phase of action.

$$w_i(\text{phase}) = \frac{e^{\beta_p \theta_i}}{\sum_{j=1}^n e^{\beta_p \theta_j}},$$

where $\text{phase} \in \{\text{login, grant, access, continuous access}\}$.

2) ATTRIBUTE PENALTY FORMULATION

While attribute weights determine how trust is accumulated through positive evidence, attribute penalties model the loss of trust when expected evidence is absent or contradicts it. In a Zero Trust system, both missing and mismatched attributes constitute negative evidence, with different security implications.

a: PENALTY TYPES FOR MISSING AND MISMATCHED ATTRIBUTES

For each attribute a_i , two penalty parameters are maintained:

- π_i^{miss} : penalty applied when the attribute a_i is missing from the observed context.
- π_i^{mm} : penalty applied when the attribute a_i is present but mismatches its expected or bound value.

3) INTEGRATION OF ATTRIBUTE PENALTIES INTO TRUST COMPUTATION

The overall trust score incorporates both weights and penalties:

$$\begin{aligned} \text{Trust}(C(t)) = & \sum_i w_i^{(t)} \text{Indicator}.\text{[match}(a_i)] \\ & - \sum_i \pi_i^{\text{miss},(t)} \text{Indicator}.\text{[missing}(a_i)] \\ & - \sum_i \pi_i^{\text{mm},(t)} \text{Indicator}.\text{[mismatch}(a_i)], \end{aligned} \quad (19)$$

enabling the accumulation and degradation of trust in accordance with Zero Trust principles.

4) ATTRIBUTE WEIGHT INITIALIZATION STRATEGIES

In the proposed system, attribute weights are derived from attribute properties such as entropy, spoofability, reliability, and attack correlation. Attribute weight derivation operates under three regimes, depending on the availability of empirical data.

a: INITIALIZATION USING HISTORICAL OBSERVATIONS

When sufficient historical data is available, attribute weights are initialized using evidence derived from prior authentication and access logs. This process combines entropy, Bayesian estimation of attack correlation, and structural attribute properties to derive an initial utility score for each attribute.

Let a_i denote an attribute and $R \in \{0, 1\}$ denote the security outcome, where $R = 1$ corresponds to an adversarial event.

Historical logs are analyzed to compute the entropy of R and the conditional entropy of R given attribute a_i .

Shannon entropy of the attack and conditional entropy are computed as:

$$H(R) = - \sum P(R) \log_2 P(R) \quad (20)$$

$$H(R | a_i) = \sum_{v \in V_i} P(a_i = v) H(R | a_i = v), \quad (21)$$

where V_i represents the set of all possible values that the attribute a_i can take. Information gain $IG(a_i)$ of attribute a_i

$$IG_{a_i} = H(R) - H(R | a_i), \quad (22)$$

quantifies the reduction in uncertainty about the security outcome after observing the attribute.

In parallel, the attack correlation of attribute a_i is modeled as a Bayesian random variable:

$$\rho_i = \Pr(R = 1 | a_i),$$

with a Beta prior initialized from historical attack and benign observations. The posterior mean,

$$\mathbb{E}[\rho_i] = \frac{\alpha_i}{\alpha_i + \beta_i}, \quad (23)$$

provides the estimate of the likelihood that the presence of a_i is associated with adversarial behavior.

Using these quantities, the initial utility of attribute a_i is defined as:

$$\theta_i^{(0)} = \lambda_1 IG_{a_i} + \lambda_2 D_i + \lambda_3 \mathbb{E}[\rho_i] - \lambda_4 S_i, \quad (24)$$

where D_i denotes the temporal stability of the attribute, S_i denotes its spoofability, and $\lambda_k > 0$ are policy-defined coefficients reflecting the relative importance of each factor.

The initial attribute weights are then computed using softmax normalization:

$$w_i^{(0)} = \frac{e^{\beta \theta_i^{(0)}}}{\sum_j e^{\beta \theta_j^{(0)}}}$$

ensuring contributions across attributes.

Algorithm 9 represents attribute weight initialization using historical evidence.

b: INITIALIZATION USING EXPERT KNOWLEDGE

When no attack history logs exist, and only expert knowledge is available to set attribute values, the expert defines initial utility scores for attributes $\theta_i^0 = \theta_i^{expert}$.

In the absence of historical observations linking attributes to security outcomes, the expert assigns θ_i^0 and embeds an initial ρ_i^0 as a prior belief. The initial attribute weights are computed based on the $\theta_i^{(0)}$ as:

$$w_i^{(0)} = \frac{e^{\beta \theta_i^{(0)}}}{\sum_{j=1}^n e^{\beta \theta_j^{(0)}}}$$

Algorithm 10 denotes attribute utilities and weights initialization using expert knowledge alone, in the absence

Algorithm 9 Attribute Weight Initialization With Historical Data

Require: Attribute set $A = \{a_1, a_2, \dots, a_n\}$

Require: Historical log dataset $\mathcal{L}$

Require: Structural attribute properties $\{S_i, D_i\}$

Require: Initial Beta prior parameters $\{(\alpha_i, \beta_i)\}$

Require: Coefficients $\lambda_1, \lambda_2, \lambda_3, \lambda_4 > 0$

Require: Inverse temperature $\beta > 0$

Ensure: Initial and updated attribute weights $\{w_i^{(t)}\}$

▷ **Offline Phase: Batch Initialization Using Historical Data**

1: **for** each attribute $a_i \in A$ **do**

2: Compute: $IG(a_i) \leftarrow H(R) - H(R | a_i)$

3: Count attack and benign occurrences (α_i, β_i)

4: Compute posterior mean $\mathbb{E}[\rho_i^{(0)}]$, utility $\theta_i^{(0)}$

5: **end for**

▷ **Compute Initial Weights**

6: **for** each attribute $a_i \in A$ **do**

7: $w_i^{(0)} \leftarrow \text{softmax}(\beta, \theta_i^{(0)})$

8: **end for**

return $\{w_i^{(0)}\}$

of historical data. Structural properties such as spoofability and temporal stability are encoded in baseline utilities, while Bayesian priors are initialized to enable subsequent learning.

Algorithm 10 Offline Expert-Only Attribute Utility Initialization

Require: Attribute set $A = \{a_1, a_2, \dots, a_n\}$

Require: Expert-defined baseline utilities $\{\theta_i^{(0)}\}_{i=1}^n$

Require: Initial Beta prior parameters $\{\alpha_i^{(0)}, \beta_i^{(0)}\}_{i=1}^n$

Require: Inverse temperature parameter $\beta > 0$

Ensure: Initial attribute weights $\{w_i^{(0)}\}_{i=1}^n$

▷ **Initialize attribute utilities and priors**

1: **for** each attribute $a_i \in A$ **do**

2: $\theta_i \leftarrow \theta_i^{(0)}$

3: $\rho_i \sim \text{Beta}(\alpha_i^{(0)}, \beta_i^{(0)})$

4: **end for**

▷ **Compute initial weights**

5: **for** each attribute $a_i \in A$ **do**

6: $w_i^{(0)} \leftarrow \text{softmax}(\beta, \theta_i)$

7: **end for**

return $\{w_i^{(0)}\}_{i=1}^n$

c: INITIALIZATION UNDER MAXIMAL UNCERTAINTY

When reliable estimates of $\{E_i, D_i, S_i, \rho_i\}$ are unavailable, the system adopts a uniform fallback initialization:

$$w_i = \frac{1}{n}, \quad \forall a_i \in A$$

This fallback represents a non-informative prior and total uncertainty over the attributes, ensuring unbiased baseline behavior. As empirical observations accumulate, the system

transitions from uniform to entropy-driven weights without altering the underlying trust or authorization logic.

5) ATTRIBUTE PENALTY INITIALIZATION STRATEGIES

Similar to attribute weights, penalties are initialized under three distinct regimes depending on information availability.

a: INITIALIZATION USING HISTORICAL OBSERVATIONS

When historical logs are available, penalties are initialized using empirical attack correlation. Let:

$$\begin{aligned}\rho_i^{\text{miss}} &= \Pr(R = 1 \mid a_i \text{ missing}), \\ \rho_i^{\text{mm}} &= \Pr(R = 1 \mid a_i \text{ mismatched}),\end{aligned}$$

be modeled using Beta distributions. The initial penalties are then defined as:

$$\pi_i^{\text{miss},(0)} = \nu_1 \mathbb{E}[\rho_i^{\text{miss}}], \quad \pi_i^{\text{mm},(0)} = \nu_2 \mathbb{E}[\rho_i^{\text{mm}}],$$

with $\nu_2 > \nu_1$, ensuring stronger penalties for mismatches.

b: INITIALIZATION USING EXPERT KNOWLEDGE

When expert knowledge is available but historical data is absent, penalties are initialized based on structural attribute properties such as spoofability and temporal stability:

$$\pi_i^{\text{miss},(0)} = \mu_1 S_i + \mu_2 (1 - D_i), \quad (25)$$

$$\pi_i^{\text{mm},(0)} = \pi_i^{\text{miss},(0)} + \Delta_i, \quad (26)$$

where S_i denotes spoofability, D_i denotes temporal stability, and $\mu_k, \Delta_i > 0$ are policy-defined coefficients reflecting the severity of negative evidence.

c: INITIALIZATION UNDER MAXIMAL UNCERTAINTY

In the absence of both expert guidance and historical data, penalties are initialized uniformly:

$$\pi_i^{\text{miss},(0)} = \pi_{\text{base}}^{\text{miss}}, \quad \pi_i^{\text{mm},(0)} = \pi_{\text{base}}^{\text{mm}},$$

where $\pi_{\text{base}}^{\text{mm}} > \pi_{\text{base}}^{\text{miss}}$ are conservative, policy-defined constants.

6) ONLINE LEARNING AND ADAPTATION OF WEIGHTS AND PENALTIES

Once the baseline weights and penalties are defined, the system continues to learn and recalibrate its values as data accumulates. At this stage, the system transitions into an entropy-based learning regime.

a: ONLINE RECALIBRATION OF ATTRIBUTE WEIGHT

As the system operates, new session outcomes are observed and incorporated into the model. The Beta posterior parameters (α_i, β_i) are updated incrementally based on observed attack and benign events, generating an updated posterior mean $\mathbb{E}[\rho_i^{(t)}]$. Initially, attribute weights are dominated by expert priors or arbitrary assignments. As observations accumulate, Bayesian posterior means and entropy-based information gain gradually shift importance towards attributes that correlate with attacks.

Every time the system observes attribute a_i :

$$(\alpha_i, \beta_i) \leftarrow \begin{cases} (\alpha_i + 1, \beta_i), & (\text{Attack} \mid a_i) = 1 \\ (\alpha_i, \beta_i + 1), & (\text{Attack} \mid a_i) = 0 \end{cases} \quad (27)$$

The system computes the updated risk correlation and the posterior mean of ρ_i as:

$$\rho_i^{(t)} = \mathbb{E}[\rho_i \mid \alpha_i, \beta_i] = \frac{\alpha_i}{\alpha_i + \beta_i}$$

Information gain may be recomputed periodically or updated incrementally. With information gain $IG(a_i)$ of attribute a_i

$$IG_{a_i} = H(R) - H(R \mid a_i),$$

, the overall attribute utility at time t relative to its initial value is defined as:

$$\theta_i^{(t)} = \theta_i^{(0)} + \eta_1 (\mathbb{E}[\rho_i^{(t)}] - \mathbb{E}[\rho_i^{(0)}]) + \eta_2 (IG_{a_i}^{(t)} - IG_{a_i}^{(0)}), \quad (28)$$

where $\eta_1, \eta_2 > 0$ controls the sensitivity of utility updates to newly observed evidence.

Updated attribute weights $w_i^{(t)}$ are obtained via softmax normalization and used in subsequent trust computation and adaptive enforcement decisions.

$$w_i^t = \frac{e^{\beta \theta_i^t}}{\sum_{j=1}^n e^{\beta \theta_j^t}},$$

where $\beta > 0$ determines how a difference in the attribute's utility affects the weight derivation of the attribute.

Algorithm 11 incrementally refines attribute utilities and weights using Bayesian updating and entropy-based information gain. This enables adaptation from cold start or arbitrary assignment to data-driven operation, based on accumulating evidence.

b: ONLINE RECALIBRATION OF PENALTIES

The penalty recalibration process operates on penalty signals obtained by dynamic attribute analysis, adjusting their impact on trust and risk based on accumulated evidence and system policy.

As new session outcomes are observed, penalties are updated incrementally using Bayesian estimation. Separate Beta posteriors are maintained for missing and mismatched events and updated based on observed attack or benign outcomes.

Penalties are recalibrated using a delta-based update:

$$\pi_i^{\text{miss},(t)} = \pi_i^{\text{miss},(t-1)} + \gamma_{\text{miss}} (\mathbb{E}[\rho_i^{\text{miss},(t)}] - \mathbb{E}[\rho_i^{\text{miss},(t-1)}]), \quad (29)$$

$$\pi_i^{\text{mm},(t)} = \pi_i^{\text{mm},(t-1)} + \gamma_{\text{mm}} (\mathbb{E}[\rho_i^{\text{mm},(t)}] - \mathbb{E}[\rho_i^{\text{mm},(t-1)}]), \quad (30)$$

subject to predefined bounds $\pi_i^{\min} \leq \pi_i^{(\cdot)} \leq \pi_i^{\max}$. This formulation ensures stable learning while preventing unbounded trust loss.

Algorithm 12 records incremental recalibration of attribute penalties based on accumulating evidence.

Algorithm 11 Online Attribute Weight Recalibration via Bayesian Learning**Require:** Attribute set $A = \{a_1, a_2, \dots, a_n\}$ **Require:** Initialized utilities $\{\theta_i^{(0)}\}_{i=1}^n$ **Require:** Initialized Beta parameters $\{\alpha_i, \beta_i\}_{i=1}^n$ **Require:** Learning coefficients $\alpha_1, \alpha_2 > 0$ **Require:** Inverse temperature parameter $\beta > 0$ **Ensure:** Updated attribute weights $\{w_i^{(t)}\}_{i=1}^n$

```

1: while new session observation ( $C(t), R(t)$ ) is available do
     $\triangleright$  Update attack correlation posteriors
2:   for each attribute  $a_i \in C(t)$  do
3:     if  $R(t) = 1$  then
4:        $\alpha_i \leftarrow \alpha_i + 1$   $\triangleright$  Attack observed
5:     else
6:        $\beta_i \leftarrow \beta_i + 1$   $\triangleright$  Benign observed
7:     end if
8:   end for
9:   for each attribute  $a_i \in A$  do
10:    Compute:  $\mathbb{E}[\rho_i], IG(a_i)$ 
11:    Update utility  $\theta_i^{(t)}$ 
12:   end for
13:   for each attribute  $a_i \in A$  do
14:     $w_i^{(t)} \leftarrow \text{softmax}(\beta, \theta_i^{(t)})$ 
15:   end for
16: end while
return  $\{w_i^{(t)}\}_{i=1}^n$ 

```

7) BASELINE ATTRIBUTE WEIGHTING ASSUMPTION

Although NIST standards primarily define requirements for authentication mechanisms, they explicitly permit and encourage the use of contextual and behavioral attributes for risk-based and continuous authorization decisions, provided such attributes are not treated as standalone authenticators. Table 6 showcases indicative baseline values of weights and penalties for the composite attribute set defined in Table 2.

The expert priors defined in this work align with these guidelines and serve solely as initial conditions that are progressively refined through empirical learning.

S. AUTHENTICATION STRENGTH AND PENALTY ASSIGNMENT MODEL**1) AUTHENTICATION STRENGTH FORMULATION****a: DEFINITION OF AUTHENTICATION STRENGTH**

Definition 1: The authentication weight w_m reflects the relative exposure of an authentication method to an adversary and its contribution to the overall attack surface. w_m provides the degree of likelihood that an adversary will target method m .

Authentication weights do not represent security strength. Instead, weights scale the impact of a successful break rather than reducing its likelihood.

Let m denote an authentication method. The authentication strength of m , denoted as $S(m)$, is defined as:

Algorithm 12 Online Bayesian Attribute Penalty Recalibration**Require:** Attribute set A **Require:** Initialized penalties $\{\pi_i^{\text{miss}}, \pi_i^{\text{mm}}\}$ **Require:** Learning coefficients $\alpha_1, \alpha_2 > 0$ **Require:** Penalty learning rates $\gamma_{\text{miss}}, \gamma_{\text{mm}} > 0$ **Require:** Penalty bounds $\pi_i^{\text{min}}, \pi_i^{\text{max}}$ **Ensure:** Updated penalties

```

1: while new session ( $C(t), R(t)$ ) observed do
     $\triangleright$  Penalty learning for missing and mismatched attributes
2:   for each attribute  $a_i \in A$  do
3:     if  $a_i$  is missing in  $C(t)$  then
4:       if  $R(t) = 1$  then
5:          $\pi_i^{\text{miss}} \leftarrow \min(\pi_i^{\text{miss}} + \gamma_{\text{miss}}, \pi_i^{\text{max}})$ 
6:       else
7:          $\pi_i^{\text{miss}} \leftarrow \max(\pi_i^{\text{miss}} - \gamma_{\text{miss}}, \pi_i^{\text{min}})$ 
8:       end if
9:     else if  $a_i$  mismatches baseline in  $C(t)$  then
10:      if  $R(t) = 1$  then
11:         $\pi_i^{\text{mm}} \leftarrow \min(\pi_i^{\text{mm}} + \gamma_{\text{mm}}, \pi_i^{\text{max}})$ 
12:      else
13:         $\pi_i^{\text{mm}} \leftarrow \max(\pi_i^{\text{mm}} - \gamma_{\text{mm}}, \pi_i^{\text{min}})$ 
14:      end if
15:    end if
16:   end for
17: end while
return  $\{\pi_i^{\text{miss}}, \pi_i^{\text{mm}}\}$ 

```

$$S(m) = f(H_m, R_m, B_m, L_m),$$

where

- H_m represents credential entropy or cryptographic strength
- R_m represents resistance to attacks
- B_m represents how tightly m can bind to the user, device, or session context
- L_m represents life cycle assurance

b: RELATIONSHIP TO AUTHENTICATION ASSURANCE LEVELS

Authentication strength provides a quantitative mapping to authentication assurance levels. A mapping function $\phi(\cdot)$ associates strength values with required assurance thresholds:

$$\text{AAL}(m) = \phi(\hat{S}(m)), \quad (31)$$

where $\phi(\cdot)$ is indicative and aligns with the assurance requirements defined in NIST SP 800-63B.

c: DEFINITION OF AUTHENTICATION UTILITY

Let $M = \{m_1, m_2, \dots, m_k\}$ denote the set of authentication methods. Each method m is characterized by:

- $S(m)$: authentication strength,

TABLE 6. Indicative attribute weights and penalties from expert priors.

Attribute	$\theta_i^{(0)}$	$w_i^{(0)}$	π_i	π_i^{miss}	$\lambda_i^{\text{mm}}/\lambda_i^{\text{miss}}$	Security Rationale
Device Serial / UUID	2.5	0.12	0.6	0.7	0.6 / 0.7	Static identifier; useful only when bound; moderate penalty on mismatch.
Application Authenticity Data	3.0	0.22	1.0	1.0	0.9 / 1.0	Cryptographic integrity signal; mismatch or absence strongly indicates an attack.
Application ID / Package Name	2.0	0.08	0.5	0.6	0.6 / 0.7	Contextual identifier; spoofable without integrity validation.
Manufacturer / Device Model	1.5	0.05	0.3	0.4	0.4 / 0.5	Low entropy; useful only in aggregate; weak standalone signal.
Platform / OS Version	2.0	0.08	0.6	0.7	0.6 / 0.7	Vulnerability exposure signal; outdated versions increase risk.
Application Version	2.0	0.08	0.6	0.7	0.6 / 0.7	Correlates with exploitability; mismatch penalized moderately.
Is Virtual	2.5	0.12	0.7	0.8	0.7 / 0.8	Virtualized environments historically abused; higher scrutiny required.
User-Agent	0.8	0.02	0.2	0.2	0.3 / 0.3	Attacker-controlled header; minimal weight and penalty.
IP Address	1.5	0.05	0.4	0.5	0.5 / 0.6	Location hint only; high churn expected in benign scenarios.
Geo-location	2.0	0.08	0.6	0.7	0.6 / 0.7	Useful anomaly signal; moderate spoofability.
GPS Location	2.5	0.12	0.7	0.8	0.7 / 0.8	Higher fidelity location; inconsistency strongly suspicious.
Time Zone / Localization	1.0	0.03	0.3	0.3	0.4 / 0.4	Low entropy; supportive only when combined with other signals.
Screen Resolution	0.8	0.02	0.2	0.2	0.3 / 0.3	Highly mutable fingerprint; privacy-sensitive and weak.
Time of Login	1.5	0.05	0.4	0.4	0.5 / 0.5	Behavioral anomaly indicator; moderate discriminative power.
Attempts During Cool-off	2.5	0.12	0.9	0.9	0.9 / 0.9	Strong credential-stuffing indicator; aggressive trust collapse.
Number of Attempts	2.0	0.08	0.8	0.8	0.8 / 0.8	Explicit attack signal per NIST; high penalty.
Time to Answer Challenge	2.0	0.08	0.6	0.6	0.6 / 0.6	Bot / automation indicator; moderate penalty.
Request Type	1.5	0.05	0.6	0.6	0.6 / 0.6	Privilege-sensitive context; mismatch risky during access phase.

- $\text{Rel}(m) \in [0, 1]$: reliability,
- $\text{PR}(m) \in [0, 1]$: phishing resistance,
- $\text{Pr}[\text{Break}(m)]$: probability of compromise.

The authentication method utility score is defined as:

$$U_m = \gamma_S \log S(m) + \gamma_R \text{Rel}(m) + \gamma_P \text{PR}(m) - \gamma_B \text{Pr}[\text{Break}(m)] \quad (32)$$

where $\gamma_S, \gamma_R, \gamma_P, \gamma_B \geq 0$ and:

$$\gamma_S + \gamma_R + \gamma_P + \gamma_B = 1$$

The value of $S(m)$ is driven by its entropy score. The utility function takes the logarithmic value of $S(m)$ to ensure it does not dominate over the other properties.

d: COMPUTATION OF AUTHENTICATION METHOD SCORES

Authentication method weights are computed as:

$$w_m = \frac{e^{\lambda U_m}}{\sum_{m' \in M} e^{\lambda U_{m'}}}$$

where $\lambda > 0$ controls sensitivity. By construction:

$$\sum_{m \in M} w_m = 1$$

e: INTEGRATION OF AUTHENTICATION WEIGHTS INTO THREAT MODELING

The weighted authentication-phase attack probability is defined as:

$$\begin{aligned} & \text{Pr}[\text{Attack}_{\text{auth}} | C] \\ &= \left(\sum_{m \in M} w_m \text{Pr}[\text{Break}(m)] \right) \cdot \prod_{i=1}^n \text{Pr}[\text{Forge}(a_i) | C]^{w_i} \quad (33) \end{aligned}$$

2) AUTHENTICATION PENALTY FORMULATION

a: DEFINITION OF AUTHENTICATION PENALTY

Definition 2 (Authentication Penalty): An authentication penalty $\Pi_m(t)$ represents a reactive measure the system undertakes by reducing the effective authentication assurance in response to observed failures, degradation, or fallback behavior associated with authentication method m .

Let m denote an authentication method invoked at time t . An authentication penalty quantifies the degradation in trust caused by failed, weak, or downgraded authentication during an authentication or re-authentication event.

The authentication penalty is defined as a function:

$$\Pi_m(t) = f(\text{Auth}_{\text{fail}}, \text{Auth}_{\text{deg}}, \text{Auth}_{\text{fallback}})$$

b: PENALTY TYPES FOR AUTHENTICATION METHODS

The system defines the following authentication penalty types:

- 1) Authentication failure penalty $\Pi_m^{fail}(t)$, when an authentication challenge using m fails.

$$\Pi_m^{fail}(t) = \begin{cases} \pi_m^{fail}, & \text{if AuthFail}(m, t) \\ 0, & \text{otherwise,} \end{cases}$$

where $\pi_m^{fail} > 0$

- 2) Authentication degradation penalty, applied when the method m does not meet the required assurance for the current context $C(t)$.

$$\Pi_m^{deg}(t) = \begin{cases} \pi_m^{deg} * \Delta S, & \text{if } S(m) < S_{req}(C(t)) \\ 0, & \text{otherwise,} \end{cases}$$

where $S(m)$ is the authentication strength of m , $S_{req}(C(t))$ is the strength required by the context, and $\Delta S = S_{req}(C(t)) - S(m)$

- 3) Authentication fallback penalty, applied when a weaker method is used after a stronger method was requested or failed.

$$\Pi_m^{fallback}(t) = \begin{cases} \pi_m^{fb}, & \text{if fallback to } m \text{ occurs} \\ 0, & \text{otherwise,} \end{cases}$$

where $\pi_m^{fb} > 0$

Typically, $\pi_m^{fb} > \pi_m^{deg} \geq \pi_m^{fail}$ and the cumulative authentication penalty is modeled as:

$$\Pi_m(t) = \Pi_m^{fail}(t) + \Pi_m^{deg}(t) + \Pi_m^{fallback}(t) \quad (34)$$

The ordering $\pi_m^{fb} > \pi_m^{deg} \geq \pi_m^{fail}$ reflects the increasing severity of authentication control degradation, consistent with risk management guidance in NIST SP 800-30 and NIST SP 800-37, and in the authentication literature [56], [57], [58], [59].

c: INTEGRATION OF AUTHENTICATION PENALTIES INTO TRUST COMPUTATION

Authentication penalties reduce the overall trust score of a context $C(t)$, modeled as:

$$Trust(t) = Trust(C(t)) - \sum_{m \in M(t)} \Pi_m(t)$$

3) AUTHENTICATION STRENGTH INITIALIZATION STRATEGIES

Authentication strength initialization defines the baseline assurance associated with each authentication method prior to any runtime observations. The authentication method strength initialization strategies depend on historical observations, the availability of standards guidance, and expert knowledge. These strategies differ only in how the initial strength value is instantiated; the subsequent enforcement and adaptation logic remains unchanged.

a: INITIALIZATION USING STANDARDS AND HISTORICAL OBSERVATIONS

When standards, guidance, and historical security data are available, authentication strength is initialized based on the intrinsic properties of the authentication method and its alignment with established assurance requirements.

Let $S(m) = f(H_m, R_m, B_m, L_m)$ denote the intrinsic strength formulation defined in Section V-S1. Initial strength values are computed as:

$$S^{(0)}(m) = \log(1 + \omega_1 H_m + \omega_2 R_m + \omega_3 B_m + \omega_4 L_m), \quad (35)$$

where the constituent properties are instantiated using method-specific characteristics derived from standards such as NIST SP 800-63B and industry best practices. The logarithmic conversion ensures stronger properties do not dominate the result.

The normalized strength $\hat{S}^{(0)}(m)$ is then mapped to an NIST authentication assurance level using a monotonic mapping function:

$$AAL(m) = \phi(\hat{S}^{(0)}(m)),$$

This mapping is indicative.

b: INITIALIZATION USING EXPERT KNOWLEDGE

In the absence of authoritative standards mappings or sufficient historical data, authentication strength may be initialized using expert knowledge. This approach helps in deriving authentication strengths in case of customized, proprietary, enterprise-specific, or emerging authentication mechanisms for which standardized assurance levels are not yet established. Domain experts assign an initial utility score θ_m^{expert} that reflects the expected cryptographic hardness, attack resistance, binding properties, and life cycle guarantees of the method:

$$S^{(0)}(m) = U_m^{\text{expert}}.$$

c: INITIALIZATION UNDER MAXIMAL UNCERTAINTY

When neither standards guidance nor expert knowledge is available, authentication strength is initialized conservatively under maximal uncertainty. All authentication methods are assigned a uniform baseline strength:

$$S^{(0)}(m) = S_{\text{base}},$$

where S_{base} is a policy-defined constant representing minimal assurance. This strategy ensures safe default behavior while avoiding overestimation of authentication assurance.

In the absence of prior data, the system initializes the authentication method utility coefficients from (32) uniformly, as:

$$\gamma_S = \gamma_R = \gamma_P = \gamma_B = \frac{1}{4}$$

Under this assumption, the authentication method utility function modeled in (32) reduces to:

$$U_m = \frac{1}{4} (\log S(m) + \text{Rel}(m) + \text{PR}(m) - \text{Pr}[\text{Break}(m)])$$

This uniform initialization treats all security-relevant properties of an authentication method as equally important. The resulting utility U_m is interpreted as a security score and is normalized via softmax to obtain the authentication method weight:

$$w_m = \frac{e^{\lambda U_m}}{\sum_{m' \in M} e^{\lambda U_{m'}}}$$

The uniform initialization is adopted solely for baseline evaluation and reproducibility; the coefficients γ_i can be re-estimated or adapted using security outcomes once the system is operational.

Regardless of the initialization strategy, authentication strength is treated as an intrinsic, static property of the authentication method. Runtime behavior, authentication outcomes, and contextual factors do not modify $S(m)$ directly and are instead captured through authentication penalties and contextual trust signals. Authentication strengths are recalibrated as standards evolve (e.g., NIST standards revision), when exploitation of the method is reported, or cryptographic breaks occur.

This separation ensures that differences between initialization strategies affect only baseline assurance and do not alter threat modeling assumptions or enforcement decisions.

4) AUTHENTICATION PENALTY INITIALIZATION STRATEGIES

a: INITIALIZATION USING STANDARDS AND HISTORICAL OBSERVATIONS

When historical data is available, penalties are initialized using empirical attack correlations. We model the Beta distribution:

$$\rho_m^x = \text{Pr}(R = 1 \mid x), \quad x \in \{\text{fail}, \text{degrade}, \text{fallback}\},$$

as the probability distribution of an attack scenario. Initial penalties are defined as:

$$\pi_m^{x,(0)} = \kappa_x \mathbb{E}[\rho_m^x],$$

with $\kappa_{\text{fb}} > \kappa_{\text{deg}} \geq \kappa_{\text{fail}}$.

b: INITIALIZATION USING EXPERT KNOWLEDGE

In the absence of historical data, penalties are initialized using expert-defined priors reflecting the intrinsic weakness of the authentication method:

$$\pi_m^{x,(0)} = \mu_x (1 - S(m)), \quad x \in \{\text{fail}, \text{degrade}, \text{fallback}\}, \quad (36)$$

with $\mu_{\text{fb}} > \mu_{\text{deg}} \geq \mu_{\text{fail}}$.

c: INITIALIZATION UNDER MAXIMAL UNCERTAINTY

When neither historical data nor expert knowledge is available, conservative defaults are used:

$$\pi_m^{x,(0)} = \pi_{\text{base}}^x, \quad x \in \{\text{fail}, \text{degrade}, \text{fallback}\},$$

with $\pi_{\text{base}}^{\text{fb}} > \pi_{\text{base}}^{\text{deg}} \geq \pi_{\text{base}}^{\text{fail}}$.

5) ONLINE LEARNING AND ADAPTATION OF AUTHENTICATION PENALTIES

The penalty recalibration process operates on instantaneous penalty signals generated by dynamic attribute analysis, adjusting their impact on trust and risk based on accumulated evidence and system policy.

For each penalty type x , a Beta posterior $\rho_m^x \sim \text{Beta}(\alpha_m^x, \beta_m^x)$ is maintained. Upon observing a session outcome $R(t)$, the posterior parameters are updated as:

$$\alpha_m^x \leftarrow \alpha_m^x + \mathbf{1}[R(t) = 1], \quad \beta_m^x \leftarrow \beta_m^x + \mathbf{1}[R(t) = 0] \quad (37)$$

Penalties are recalibrated using a delta-based update rule:

$$\pi_m^{x,(t)} = \pi_m^{x,(t-1)} + \gamma_x (\mathbb{E}[\rho_m^{x,(t)}] - \mathbb{E}[\rho_m^{x,(t-1)}]), \quad (38)$$

subject to bounds $\pi_m^{\min} \leq \pi_m^{x,(t)} \leq \pi_m^{\max}$.

T. INTEGRATION OF AUTHENTICATION STRENGTH AND PENALTIES INTO AUTHORIZATION THRESHOLDS

Authorization decisions in the proposed framework are governed by both the intrinsic assurance provided by authentication methods and the dynamic trust and risk signals accumulated during system interaction. Authentication strength acts as a minimum assurance gate, while authentication penalties dynamically adjust the effective trust and attack success probability.

1) PENALTY-ADJUSTED EFFECTIVE AUTHENTICATION STRENGTH

Authentication penalties degrade the effective assurance of an authentication method without modifying its intrinsic strength. We define the penalty-adjusted authentication strength as:

$$\hat{S}_{\text{eff}}(m, t) = \hat{S}(m) - \lambda_{\Pi} \cdot \Pi_m(t), \quad (39)$$

where $\Pi_m(t)$ is the cumulative authentication penalty and $\lambda_{\Pi} > 0$ is a policy-defined scaling factor.

2) PENALTY-ADJUSTED TRUST THRESHOLD

Authentication penalties also influence authorization indirectly through trust degradation:

$$\text{Trust}(C(t)) = \text{Trust}_{\text{attr}}(C(t)) - \sum_{m \in \mathcal{M}(t)} \Pi_m(t), \quad (40)$$

ensuring that repeated authentication failures or downgrade attempts rapidly reduce trust below authorization thresholds for sensitive resources.

3) AUTHORIZATION GRANT CONDITION

Let R_s denote a protected resource with sensitivity level $\sigma(R_s)$. An authorization grant event at time t is defined as

$$E_g(t) = (S(t), C(t), \mathcal{T}, t),$$

where $S(t)$ is the active authentication state, $C(t)$ is the session context, and $\mathcal{T}$ is the issued authorization token.

The authorization token grant event from (8) can be rewritten as:

$$\begin{aligned} E_g(t) \iff & \text{AuthValid}(S(t)) \wedge \hat{S}_{\text{eff}}(m, t) \geq \hat{S}_{\text{req}}(C(t), R_s) \\ & \wedge \text{Trust}(C(t)) \geq \tau_{\text{grant}}(R_s) \\ & \wedge \text{Pr}[\text{Attack Success} \mid C(t)] \leq \delta_{\text{grant}}(R_s), \end{aligned}$$

where $\hat{S}_{\text{eff}}(m)$ denotes effective authentication strength, $\hat{S}_{\text{req}}(t) = f(\text{Pr}[\text{Attack Success} \mid C(t)])$, $\tau_{\text{grant}}(R_s)$ is the minimum trust threshold, and $\delta_{\text{grant}}(R_s)$ is the maximum acceptable attack success probability, thereby allowing authentication degradation and fallback behavior to directly influence authorization outcomes.

4) PENALTY-AMPLIFIED ATTACK SUCCESS PROBABILITY

Authentication penalties represent runtime evidence of degradation, failure, or fallback behavior of authentication methods, indicating increased adversarial activity. Authentication penalties thus provide a baseline of the break probability of the authentication method and reflect elevated risk. This is in line with NIST SP 800-30, which recommends treating indicators as a measure of the likelihood of a threat.

With this, the probability of breaking an authentication method is remodeled as:

$$\text{Pr}[\text{Break}(m) \mid \Pi_m(t)] = \text{Pr}[\text{Break}(m)](1 + \eta_m \Pi_m(t)),$$

where $\Pi_m(t)$ represents the authentication penalty imposed in case of authentication challenge failure, downgrade, or fallback using m , and $\eta_m > 0$ is a method-specific sensitivity parameter.

The authentication-phase attack probability defined in (15) is redefined as:

$$\begin{aligned} & \text{Pr}[\text{Attack}_{\text{auth}} \mid C(t)] \\ &= 1 - \prod_{m \in \mathcal{M}(t)} \left(1 - \text{Pr}[\text{Break}(m)](1 + \eta_m \Pi_m(t))\right) \\ & \cdot \prod_{a_i \in C(t)} \left(1 - \text{Pr}[\text{Forge}(a_i) \mid C(t)]\right) \end{aligned}$$

This modeling contributes directly to the composite attack success probability used in authorization decisions.

5) ADAPTIVE AUTHORIZATION ENFORCEMENT

The required authentication strength at time t is defined as:

$$S_{\text{req}}(t) = f(\text{Pr}[\text{Attack Success} \mid C(t)])$$

If any condition in (V-T3) is violated, the system enforces one of the following actions based on policy:

- Step-up authentication to a stronger method m' such that $\hat{S}_{\text{eff}}(m', t) \geq \hat{S}_{\text{req}}(C(t), R_s)$;
- Token revocation or scope reduction;
- Access denial or session termination.

This mechanism enables continuous authorization, ensuring that authentication assurance, trust, and risk remain aligned with resource sensitivity throughout the session.

U. BASELINE PARAMETERIZATION FOR EVALUATION AND POLICY TUNING

Authentication strength values are indicative baselines used for evaluation and policy tuning, derived from the assurance properties defined in NIST SP 800-63B and FIDO specifications, and do not imply formal certification.

Table 7 maps common authentication methods to NIST AAL and FIDO, along with indicative baseline authentication strengths and penalties for evaluation and policy tuning.

V. DETECTING AND ENFORCING HARD VIOLATIONS

Hard violations represent non-compensable states that result in request denial and suspension of learning and recalibration. We model the computation and validation of hard violation signals below.

1) GEO-VELOCITY COMPUTATION

Geo-velocity, calculated from the time between requests and the geographic distance, is crucial for risk assessment and analysis. The geo-velocity risk model is represented using the risk Function:

$$G(v) = \begin{cases} 0 & \text{if } v \leq v_{\text{safe}} \\ \frac{v - v_{\text{safe}}}{v_{\text{max}} - v_{\text{safe}}} & \text{if } v_{\text{safe}} < v < v_{\text{max}} \\ \infty & \text{if } v \geq v_{\text{max}} \end{cases}$$

where velocity $v = \frac{\Delta d}{\Delta t}$ km/h and Δd is the Haversine distance between two consecutive logins.

The geo-velocity safe threshold v_{safe} is set between 800-1000 km/h [60]. The threshold v_{max} is set to 1000 km/h as the upper bound of plausible commercial air travel speed, allowing margin for geolocation inaccuracy and clock skew while excluding physically impossible transitions. Speeds below this threshold but exceeding normal travel rates are treated as probabilistic anomalies rather than deterministic violations. Requests with geo-velocity exceeding the hard limit are blocked and reported as risky, given typical user displacement.

Given two points with latitudes ϕ_1, ϕ_2 and longitudes λ_1, λ_2 (in radians), the Haversine distance Δd is calculated as:

$$\begin{aligned} a &= \sin^2\left(\frac{\Delta\phi}{2}\right) + \cos\phi_1 \cos\phi_2 \sin^2\left(\frac{\Delta\lambda}{2}\right), \\ c &= 2 \cdot \text{atan2}\left(\sqrt{a}, \sqrt{1-a}\right), \\ d &= R_E \cdot c, \end{aligned} \tag{41}$$

TABLE 7. Indicative baseline authentication strengths and penalties mapped to NIST AAL and FIDO.

Authentication Method	NIST AAL	FIDO Alignment	S(m)	π_m^{fail}	π_m^{deg}	π_m^{fb}	Justification
Password (Static Secret)	AAL1	None	0.20	0.20	0.40	0.50	Single-factor memorized secret; vulnerable to phishing, replay, credential stuffing, and impersonation. Minimal identity assurance, frequently exploited.
Graphical Passwords	AAL1	None	0.25	0.25	0.45	0.55	Marginally higher memorability; limited entropy and observation resistance. Failure or downgrade strongly correlates with adversarial behavior.
Password + OTP (SMS)	AAL2	None	0.45	0.15	0.30	0.40	Two-factor authentication; susceptible to SIM swap and phishing relay attacks. Fall-back to password removes second factor and significantly degrades security.
Password + OTP (TOTP/App)	AAL2	None	0.55	0.25	0.25	0.40	Improved entropy and resistance compared to SMS; vulnerable to real-time phishing.
Push-Based MFA	AAL2	None	0.60	0.10	0.25	0.35	Moderate assurance; vulnerable to MFA fatigue and social engineering. Repeated failures or downgrades indicate social-engineering risk.
FIDO2 / Passkeys (Roaming Authenticator)	AAL2	FIDO2	0.75	0.15	0.25	0.40	Phishing-resistant, strong replay and verifier impersonation resistance; failures are rare but fallback undermines strong guarantees.
FIDO2/ Passkeys (Platform Authenticator)	AAL3	FIDO2 + Hardware Protection	0.85	0.40	0.25	0.50	Phishing-resistant with hardware-backed key protection; failures are rare, but fallback undermines strong guarantees.
mTLS / Client Certificates	AAL3	None	0.90	0.35	0.30	0.55	High resistance to phishing, replay, and MITM attacks. Degradation or fallback signals severe compromise.
Smart Card / PIV	AAL3	None	0.90	0.45	0.30	0.55	Hardware-backed cryptographic credentials with strong life cycle controls and physical possession requirement.

where:

- $\Delta\phi = \phi_2 - \phi_1$ (difference in latitudes),
- $\Delta\lambda = \lambda_2 - \lambda_1$ (difference in longitudes),
- R_E is the Earth's radius (mean radius = 6,371 km),
- $\text{atan2}(y, x)$ is the two-argument arctangent function.

2) APPLICATION INTEGRITY ENFORCEMENT

With the increased penetration of smartphones, mobile applications form a major access medium. The application attributes described in Table 2 provide a contextual attribute subset that can be used to statically verify the origin of the request. The application attributes provide a way to uniquely identify “the application, running on device” combination. In addition, the proposed framework introduces two new approaches to mitigate the risk of application spoofing.

a: APPLICATION INTEGRITY CHECKS

During the first connection of the device to the system, the Cyclic Redundancy Check (CRC) value of the constituent files of the application package is computed and stored on the server. Upon each application load in the user's device, the CRC is recomputed and compared with the CRC data on the server to ensure that the binaries have not been tampered with.

b: DYNAMIC BUILD SECRET INJECTION

Dynamic Build Secret Injection comprises injecting a random value into the application properties at build time. This value is stored in the server during the first contact. If an

attacker rebuilds the application, the value changes, and can be detected by the server.

The algorithms for the application integrity check and dynamic build secret injection are presented in Algorithms 13 and 14, respectively. The corresponding anti-tampering techniques are described in Algorithm 15.

III. DEVICE INTEGRITY ENFORCEMENT

In ZT architecture, device posture is a trust signal that is given as much weight as user identity. Policy-driven specifications can detect if the device posture does not meet the policy-set requirements and deny access, even if the user identity is valid. Just as trust signals related to users' behavioral and contextual attributes are validated, device-originated attributes are also continuously monitored. The proposed ZeTHAA framework introduces an adaptive device authentication protocol that aligns with NIST guidance on device binding by combining contextual device attributes with hardware-backed verification. Passive device attributes provide evidence that adds to or degrades trust. Contextual trust degradation and risk-based escalation result in hardware challenges that require the participating device to establish a hardware-backed cryptographic binding. This adaptive device authentication protocol offers resistance to replay and device impersonation, consistent with NIST SP 800-63B and Zero Trust principles defined in NIST SP 800-207. Algorithms 16 and 17 describe the proposed Adaptive Device Authentication Protocol.

With the system definitions described, we move into the security guarantees formalized by the ZeTHAA framework.

Algorithm 13 Application Integrity Verification

Require: $serverKey \leftarrow \text{HKDF}(\text{masterKey}, \text{"checksum"})$ $\triangleright$ Key derivation

- 1: $appCRC \leftarrow 0, fileHashes \leftarrow \emptyset$
- 2: **procedure** ComputeAndRegisterChecksum($ApplicationPackage$)
- 3: **for each** $file \in ApplicationPackage$ **in parallel do**
- 4: $hash \leftarrow \text{xxHash64}(file.content)$
- 5: $fileHashes.add(hash)$
- 6: $appCRC \leftarrow appCRC \oplus hash$ $\triangleright$ XOR chaining
- 7: **end for**
- 8: $sealedCRC \leftarrow \text{HMAC-SHA256}(serverKey, appCRC)$
- 9: SecureStore($sealedCRC$) $\triangleright$ Encrypted database
- 10: **end procedure**
- 11: **procedure** VerifyChecksum($ApplicationPackage$)
- 12: $localCRC \leftarrow 0$
- 13: **for each** $file \in ApplicationPackage$ **do**
- 14: $localCRC \leftarrow localCRC \oplus \text{xxHash64}(file.content)$
- 15: **if** $file \notin fileHashes$ **then** $\triangleright$ Detect new/deleted files
- 16: Reject("Unauthorized file modification")
- 17: **end if**
- 18: **end for**
- 19: $receivedSeal \leftarrow \text{HMAC-SHA256}(serverKey, localCRC)$
- 20: **if** $receivedSeal \neq \text{SecureFetch}()$ **then**
- 21: RejectAndAudit("Integrity violation")
- 22: ReportToSIEM() $\triangleright$ Security monitoring
- 23: **end if**
- 24: **end procedure**

VI. SECURITY GUARANTEES

This section formalizes the security guarantees provided by the proposed ZeTHAA framework. The guarantees are stated relative to baseline assumptions and follow directly from the models and mechanisms introduced in the preceding sections.

A. IMPOSSIBLE TRAVEL ELIMINATION GUARANTEE

Guarantee 1 (Impossible State Elimination). The system guarantees that no authorization grant or session continuation occurs under physically or logically impossible contextual states. Formally, for any time t ,

$$\text{ImpossibleTravel}(t) = 1 \Rightarrow \text{Grant}(t) = 0.$$

$$\begin{aligned} \text{Grant}(t) \iff & \neg \text{ImpossibleTravel}(t) \wedge \text{AuthValid}(S(t)) \\ & \wedge S(m) \geq S_{\text{req}}(C(t)) \\ & \wedge \text{Pr}[\text{AttackSuccess} \mid C(t)] \leq \delta(R_s). \end{aligned} \quad (42)$$

B. SECURITY GUARANTEE: POISONING RESISTANCE

Guarantee (Profile Poisoning Resistance). Under the learning policy defined in (1)–(2), an adversary cannot significantly shift a behavioral profile through transient or

Algorithm 14 Secure Build Secret Embedding and Verification Protocol

Require: $\kappa \leftarrow 256$ $\triangleright$ Security parameter

- 1: $\mathcal{K}_{\text{wrap}} \leftarrow \text{HKDF-SHA512}(k_{\text{master}}, \text{"secret-wrap"})$
- 2: **procedure** EmbedSecret($S_{\text{src}}, \text{build_config}$)
- 3: $\sigma \leftarrow \text{PRF}(\kappa)$ $\triangleright$ 256-bit secret
- 4: $\sigma_{\text{enc}} \leftarrow \text{AES-GCM-SIV}(\mathcal{K}_{\text{wrap}}, \sigma)$
- 5: **// Obfuscated Injection**
- 6: **for each** $f_i \in \text{MatchFiles}(S_{\text{src}}, *.cpp, *.py, *.java)$ **do**
- 7: InjectAsConst($f_i, \text{base64}(\sigma_{\text{enc}}[0 : 32])$)
- 8: InjectAsComment($f_i, \text{base64}(\sigma_{\text{enc}}[32 :])$)
- 9: **end for**
- 10: CompileWithPIE($S_{\text{src}}, \text{build_config}$) $\triangleright$ Position-Independent Executable
- 11: StoreSecret($\text{HMAC-SHA256}(\mathcal{K}_{\text{wrap}}, \sigma)$)
- 12: **end procedure**
- 13: **procedure** VerifySecret(B_{app})
- 14: $\sigma_{\text{ext}} \leftarrow \text{ExtractFromBinary}(B_{\text{app}})$
- 15: $\sigma_{\text{dec}} \leftarrow \text{AES-GCM-SIV-Decrypt}(\mathcal{K}_{\text{wrap}}, \sigma_{\text{ext}})$
- 16: $\text{seal}_{\text{server}} \leftarrow \text{FetchSeal}()$
- 17: $\text{seal}_{\text{local}} \leftarrow \text{HMAC-SHA256}(\mathcal{K}_{\text{wrap}}, \sigma_{\text{dec}})$
- 18: **if** $\neg \text{SecureEqual}(\text{seal}_{\text{local}}, \text{seal}_{\text{server}})$ **then**
- 19: Reject("Tampering detected")
- 20: FireCanaryToken() $\triangleright$ Trigger deception measures
- 21: **else**
- 22: GrantAccess()
- 23: **end if**
- 24: **end procedure**

Algorithm 15 Anti-Tampering Techniques

- 1: **function** InjectAsConst($file, data$)
- 2: $\text{varName} \leftarrow \text{RandomIdentifier}()$
- 3: InsertCode($file, \text{"const auto varName = " + data + " ;"}\text{"}$)
- 4: InsertDeadCode($file, \text{varName}$) $\triangleright$ Control-flow obfuscation
- 5: **end function**
- 6: **function** ExtractFromBinary($binary$)
- 7: $\text{mem} \leftarrow \text{ReadELF/PE/MachO}(binary)$
- 8: FindXORedSegments($\text{mem}, \mathcal{K}_{\text{wrap}}[0 : 16]$)
- 9: **return** ReconstructSecret(mem)
- 10: **end function**

suspicious activity. Specifically, for any time window $\mathcal{W}$ during which $\text{Learn}(t) = 0$ for all $t \in \mathcal{W}$, the profile remains invariant:

$$\forall t \in \mathcal{W}, \quad \mathcal{P}_u^i(t+1) = \mathcal{P}_u^i(t).$$

Moreover, when learning is permitted, the maximum cumulative influence of any sequence of observations of length n is bounded by $1 - (1 - \gamma)^n$, ensuring that no finite sequence of events can rapidly redefine normal behavior.

Algorithm 16 Adaptive Device Authentication Protocol

```

1: procedure DeviceAuthentication( $C(t), \mathcal{P}_u, \theta_{\text{dev}}$ )
2:    $\Delta_{\text{pen}} \leftarrow 0$ 
3:    $D_{\text{OS}} \leftarrow \text{ExtractOSAttributes}(C(t))$ 
4:   for all  $d_i \in D_{\text{OS}}$  do
5:     if  $\text{Match}(d_i, \mathcal{P}_u(d_i)) = 1$  then
6:        $\text{Trust}(t) \leftarrow \text{Trust}(t) + w_i$ 
7:     else
8:        $\Delta_{\text{pen}} \leftarrow \Delta_{\text{pen}} + \pi_i$ 
9:     end if
10:  end for
11:  if  $\Delta_{\text{pen}} \geq \theta_{\text{dev}}$  then
12:     $D_{\text{RS}} \leftarrow \text{SelectHWChallengeSet}(D_{\text{HW}} \setminus D_{\text{OS}})$ 
13:     $\text{SendChallenge}(D_{\text{RS}})$ 
14:     $\text{BindState}(D_{\text{RS}}, C(t))$ 
15:     $\text{LearningEnabled}(t) \leftarrow 0$ 
16:  end if
17: end procedure

```

Algorithm 17 Hardware Challenge Verification

```

1: procedure VerifyDeviceChallenge( $U_{\text{id}}, C(t), D_{\text{RS}}^{\text{resp}}$ )
2:    $D_{\text{RS}}^{\text{state}} \leftarrow \text{RetrieveBoundState}(U_{\text{id}})$ 
3:   if  $\text{VerifyHWPProof}(D_{\text{RS}}^{\text{resp}}, D_{\text{RS}}^{\text{state}}) = 1$  then
4:      $\text{Trust}(t) \leftarrow \text{Trust}(t) + w_{\text{HW}}$ 
5:      $\text{LearningEnabled}(t) \leftarrow 1$ 
6:   else
7:      $\text{Trust}(t) \leftarrow \text{Trust}(t) - \pi_{\text{HW}}$ 
8:      $\text{HardViolation}(t) \leftarrow 1$ 
9:      $\text{LogSecurityEvent}(U_{\text{id}}, t)$ 
10:  end if
11: end procedure

```

1) AUTHENTICATION ASSURANCE GUARANTEE

Theorem 1 (Minimum Authentication Assurance): An authorization grant is issued only if the effective authentication strength meets or exceeds the required assurance threshold for the current context and resource sensitivity.

Proof: By construction, authorization is granted only when $\hat{S}_{\text{eff}}(m, t) \geq \hat{S}_{\text{req}}(C(t), R_s)$, where $\hat{S}_{\text{eff}}(m, t) = \hat{S}(m) - \lambda_{\Pi} \Pi_m(t)$. Since $\Pi_m(t) \geq 0$, penalties can only reduce effective strength, ensuring that authentication assurance is never overestimated. $\square$

2) MONOTONIC RISK AMPLIFICATION GUARANTEE

Theorem 2 (Penalty-Induced Risk Monotonicity): The probability of a successful authentication attack is a monotonic increasing function of accumulated authentication penalties.

Proof: The authentication attack probability is defined as:

$$\Pr(\text{Break}(m) \mid \Pi_m(t)) = \Pr(\text{Break}(m))(1 + \eta_m \Pi_m(t)),$$

with $\eta_m > 0$. Since $\Pi_m(t)$ is non-negative and increasing under negative events, the conditional break probability

increases monotonically, implying that additional penalties strictly increase adversarial success probability. $\square$

3) TRUST DEGRADATION AND RAPID LOSS GUARANTEE

Theorem 3 (Asymmetric Trust Evolution): Trust accumulates gradually through positive contextual evidence but degrades rapidly in the presence of authentication penalties or attribute violations.

Proof: Trust is computed as:

$$\text{Trust}(t) = \text{Trust}_{\text{attr}}(C(t)) - \sum_{m \in \mathcal{M}(t)} \Pi_m(t) - \sum_i \pi_i(t).$$

Positive evidence contributes additively through weighted attributes, while penalties are unbounded in frequency and additive in magnitude, ensuring faster trust decay than accumulation. $\square$

4) ADAPTIVE ENFORCEMENT GUARANTEE

Theorem 4 (Adaptive Step-Up and Revocation): If authentication strength, trust, or acceptable attack risk thresholds are violated at any time, the system enforces step-up authentication, token revocation, or access termination.

Proof: Authorization is continuously evaluated against thresholds $\hat{S}_{\text{req}}$, τ_{grant} , and δ_{grant} . Violation of any condition triggers predefined enforcement actions, ensuring that access is never maintained under insufficient assurance or excessive risk. $\square$

5) END-TO-END ZERO TRUST GUARANTEE

Theorem 5 (End-to-End Zero Trust Enforcement): Under the stated assumptions, the proposed framework ensures that no access is granted or retained solely based on prior authentication, and that all access decisions are continuously re-evaluated against current authentication assurance, contextual trust, and estimated attack risk.

Proof: Initial access requires satisfaction of authentication strength, trust, and risk constraints. Continuous monitoring updates penalties, trust, and attack probability. Any deviation from acceptable bounds triggers enforcement per Theorem 4. Therefore, trust is never implicit, persistent, or unconditional. $\square$

Having established the security guarantees, Table 8 maps the 7 NIST Zero Trust tenets to the proposed framework's security guarantees.

6) SCOPE AND LIMITATIONS

The guarantees hold relative to the accuracy of attribute measurements, the correct initialization of authentication strengths, and the timely observation of security outcomes. Compromise of these assumptions may reduce the effectiveness of enforcement, but does not invalidate the structural guarantees of monotonic risk amplification and adaptive control.

VII. EXPERIMENTAL EVALUATION**A. TESTBED AND IMPLEMENTATION**

The evaluation was conducted on a Lenovo IdeaPad running 12th Gen Intel(R) Core(TM) i5-12450H (2.00 GHz)

TABLE 8. Mapping of security guarantees to NIST zero trust tenets.

NIST ZT Tenet	Tenet Description (SP 800-207)	Corresponding Security Guarantees in Proposed Framework
T1	All data sources and computing services are considered resources.	Resource sensitivity $\sigma(R_s)$ explicitly parameterizes authentication strength thresholds, trust thresholds, and acceptable attack probability (Eq. V-T3).
T2	All communication is secured regardless of network location.	Authentication strength initialization (Section V-S3) and AAL mapping ensures cryptographic assurance independent of network trust.
T3	Access to resources is granted on a per-session basis.	Authorization grant events $E_g(t)$ are session-scoped and depend on $S(t)$, $C(t)$, and T , with no implicit persistence across sessions.
T4	Access is determined by dynamic policy, including context and risk.	Authorization requires satisfaction of authentication strength, trust, and attack-risk thresholds conditioned on $C(t)$ (V-T3).
T5	The enterprise monitors and measures the integrity and security posture of assets.	Continuous monitoring of authentication penalties, attribute mismatches, and risk updates $\text{Trust}(t)$ and $\text{Pr}[\text{Attack Success}]$ online.
T6	All resource authentication and authorization are dynamic and strictly enforced.	Adaptive enforcement guarantees step-up authentication, token revocation, or termination whenever thresholds are violated (Theorem 4).
T7	The enterprise collects as much information as possible to improve its security posture.	Bayesian learning of attribute weights, penalties, and attack correlation leverages historical observations to recalibrate trust and risk models.

TABLE 9. Dataset summary.

Metric	Value
Users	500
Sessions	50000
Events	116092
Attack Events	36262
Attack Ratio	0.312356

[H]

and 16 GB of RAM, running Windows 11 Home Edition(64-bit). To evaluate the effectiveness of the proposed ZeTHAA framework, we conducted experiments using a synthetic authentication dataset that incorporates realistic user behavior and adversarial scenarios. To ensure reproducibility, the source code, the baseline implementations, and the evaluation scripts are available at [61].

1) DATASET DESCRIPTION

The dataset contains approximately 50,000 authentication sessions across 500 users, generating close to 150,000 authentication events. Each session includes contextual attributes such as device model, operating system version, geographic location, and temporal login behavior. The dataset models user travel patterns and device life cycle events, such as new phone purchases, operating system upgrades, and application version upgrades. Approximately 70% of the sessions represent normal user behavior, while the remaining 30% model adversarial scenarios. Table 9 summarizes the overall dataset characteristics.

2) DATASET PROPERTIES

The dataset models multiple adversarial scenarios, including coordinated attack campaigns, credential theft, bot-driven login attempts, device spoofing, session hijack, token theft and replay, and application tampering. The attack classes were balanced and evenly distributed to prevent bias towards

TABLE 10. Attack distribution.

Attack Type	Count
Bot_Login	2927
Credential_Theft	3838
Access_Without_Login	3769
Application_Tampering	3306
Session_Hijack	4912
Device_Spoofing	3521
Impossible_Travel	3687
Emulator	3574
Token_Theft	3350
Device_Cloning	3378

[H]

a single attack pattern. Table 10 shows the diversity and distribution of the attack types in the dataset.

B. CONTEXTUAL RISK MODELING

The proposed framework evaluates authentication risk using contextual signals derived from device characteristics, network context, user mobility, and behavioral patterns. These signals are calibrated using evidence-based weighting to estimate their relative contribution to authentication risk.

1) CONTEXTUAL SIGNALS

Key contextual signals include:

- geographic anomaly detection
- travel status and timezone shifts
- device fingerprint consistency
- session token reuse patterns
- repeated attacker IP activity

These contextual signals capture identity, device, network, temporal, and behavioral context. The relative importance of each contextual feature was derived using Bayesian online calibration via Beta posterior updating. The calibrated results show the probability of an attack given the exposure of the attribute signal.

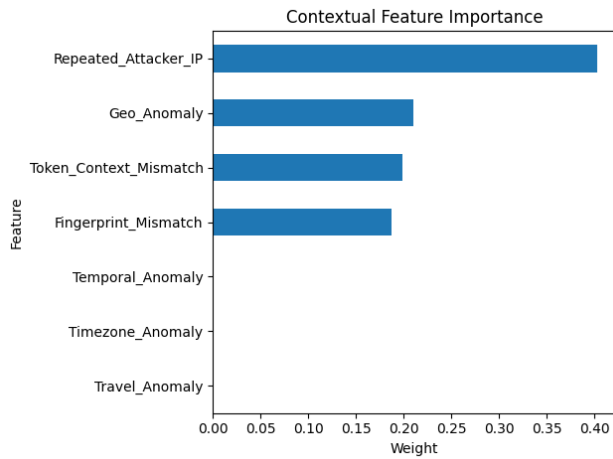


FIGURE 2. Feature importance.

2) FEATURE IMPORTANCE

The relative importance of contextual features, derived using Bayesian online calibration, is shown in Fig. 2. Attack campaign-related features contribute the highest to risk, followed by geographic anomalies. Device and session integrity-related signals, particularly fingerprint mismatch and session context inconsistencies, contribute moderately to the risk score, while temporal and travel anomalies serve as weak indicators.

C. RISK SCORE BEHAVIOR

Fig. 3 compares the distribution of risk scores by class - benign and attack sessions. The figure shows a clear separation between benign and attack events, with attack sessions showing consistently higher risk values than benign sessions. The attack classes form two clusters, with the majority of the sessions in the first cluster showing risk scores ranging from 0 to 0.11, indicating stable contextual behavior. A second group is identified with risk ranging from 0.12 to 0.4, indicating a natural separation of risk values. This demonstrates the proposed framework's ability to distinguish anomalous behavior. The distribution shows that the decision thresholds can be placed logically.

D. DECISION POLICY AND DETECTION PERFORMANCE

1) THRESHOLD SELECTION

Authentication events are classified into three regions based on their computed risk score decision thresholds. Events with risk scores below the lower threshold τ_1 are allowed without additional verification, while moderate-risk events trigger step-up authentication until the upper threshold τ_2 . Events exceeding the upper threshold are classified high risk and will result in denial of access.

The decision thresholds τ_1 and τ_2 are derived from the dataset. The upper threshold τ_2 is computed as the maximum Youden's value $youden = tpr - fpr$, where tpr denotes the true positive rate and fpr represents the false positive rate. The

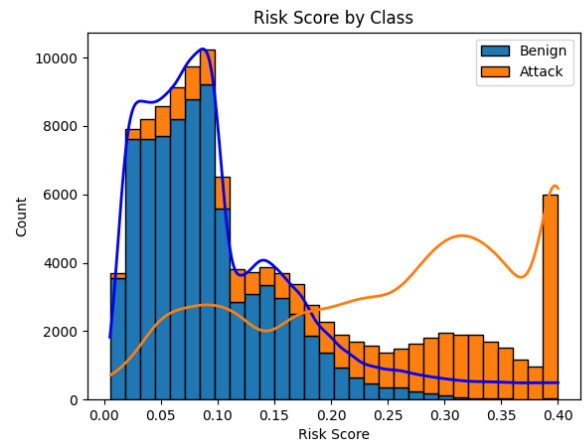


FIGURE 3. Risk score distribution by class.

TABLE 11. Decision rates.

Decision	Attack	Benign	Attack Rate	Benign Rate
ALLOW	6229	59872	17.177%	74.999%
STEP_UP	3512	13973	9.685%	17.503%
BLOCK	26521	5985	73.137%	7.49%

lower threshold τ_1 was set to the 75th percentile of benign traffic to minimize user friction.

The thresholds were subsequently derived from the dataset as:

$$\tau_1 = 0.1180, \tau_2 = 0.1809$$

2) POLICY DECISIONS

Table 11 captures the policy decisions that apply thresholds to the events.

The data shows that approximately 75% of benign events were allowed without additional verification, while 17.5% required step-up authentication. Only 7.5% of benign sessions were incorrectly blocked. In the case of attack sessions, about 73% were immediately blocked, and approximately 9.7% were subjected to step-up verification. The results show that the framework balances security and usability, minimizes user friction, and maintains attack detection.

Fig. 4 shows the policy decisions based on the risk score distribution.

The derived decision thresholds balance between security and usability. The majority of the benign events were allowed without friction, while a controlled percentage underwent step-up verification. The framework blocked a significant proportion of attack events, demonstrating the effectiveness of a risk-based policy.

E. CLASSIFICATION PERFORMANCE

To quantify the effectiveness of the proposed ZeTHAA framework, standard classification metrics were computed using the calibrated risk thresholds.

1) CONFUSION MATRIX

Table 12 presents the global confusion matrix comparing the input dataset to the ZeTHAA framework's output, while

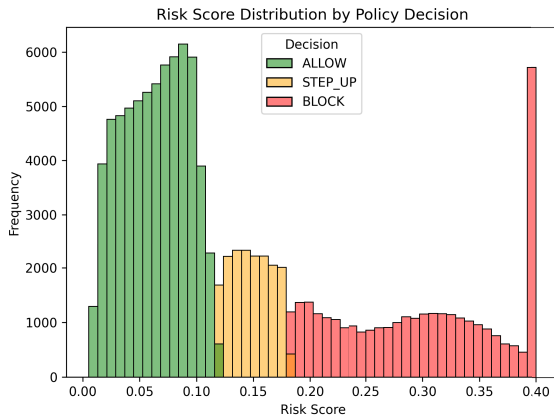


FIGURE 4. Policy decision with risk score distribution.

TABLE 12. Global confusion matrix.

	Predicted Benign	Predicted Attack
Actual Benign	73845	5985
Actual Attack	9741	26521

TABLE 13. Performance metrics.

Metric	Value
Accuracy	0.864538
Precision	0.815880
Recall	0.731372
F1 Score	0.771318
AUC	0.885444

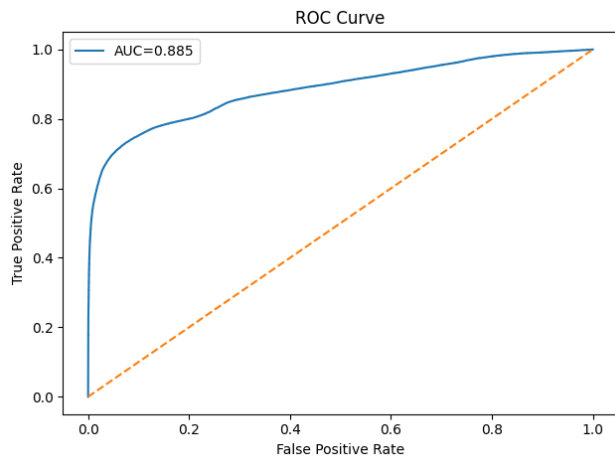


FIGURE 5. ROC curve.

the corresponding performance metrics are summarized in Table 13. Fig. 5 shows the derived Receiver Operating Characteristic (ROC) curve.

2) RISK-TRUST CORRELATION AND ATTACK CLASSIFICATION PERFORMANCE

Fig. 6 presents the correlation between risk and trust, and how the framework uses the trust score, along with the computed thresholds to classify events.

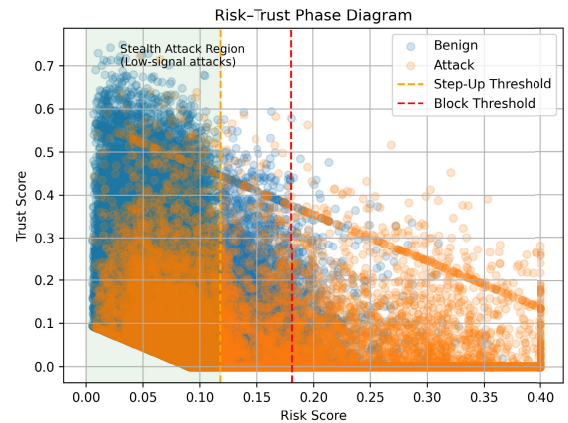


FIGURE 6. Risk-trust correlation.

TABLE 14. Stealth attack metrics.

Metric	Value
Total Attacks	36,262
Stealth Attacks ($< \tau_1$)	6,229
Stealth Attack Rate	0.1718

The low-risk phase is represented by the region with risk scores less than the step-up threshold. While this region shows a high density of benign events as expected, it also shows the presence of attack events. The subset of attacks that fall in the low-risk region can be considered stealth attacks, where adversarial behavior does not manifest strongly across the observed contextual signals. Table 14 records the number of attack events that were found in the low-risk zone.

However, even in the low-risk area, malicious activities were found to dominate the lower trust areas, while benign activities clustered in the higher trust region. This trend continues into the transition phase between the thresholds. The higher risk zone (>0.18) represents a concentration of attack events and is also characterized by a high density of events with very low trust scores. The diagonal linear trend represents the correlation between risk and trust in the framework: as the risk score increases, the trust score declines linearly. This suggests that risk alone is not sufficient to distinguish events; trust scores are the primary differentiator. Fig. 6 also closely corresponds to the findings noted in Table 11.

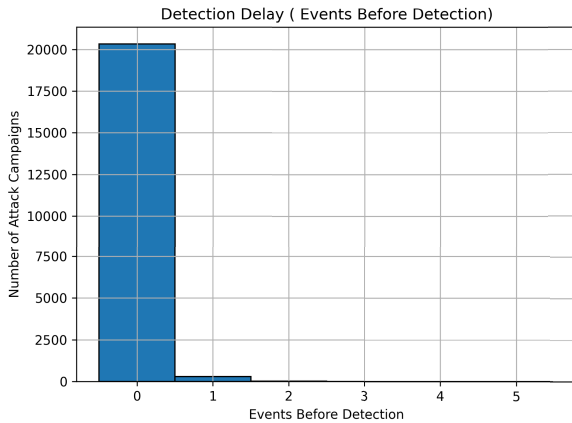
F. DETECTION LATENCY

An important requirement of an adaptive authentication system is its ability to rapidly detect malicious activity. To evaluate this aspect, the delay between the onset of an attack and the first event exceeding the block threshold τ_2 was measured. The detection latency is defined as the number of events required before the risk score crosses the block threshold τ_2 .

Table 15 records the detection performance of the proposed framework. Strong contextual signals, such as Attack campaign signatures, device fingerprint mismatches, and session

TABLE 15. Detection delay by events.

Metric	Value (No of Events)
Average Number of Events	0.0170
Median Number of Events	0.0
Max delay	3
95th percentile delay	0.0
Immediate detection rate	98.44%

**FIGURE 7. Detection delay distribution.**

context violations, elevate the aggregated risk score above the block threshold. The framework showed an immediate detection rate of 98.4%, with a 95th percentile delay of 0 events. The average delay, in terms of the number of events was 0.0170. Fig. 7 represents the distribution of detection delay by events during the attack campaigns.

G. USER FRICTION ANALYSIS

The usability of the proposed ZeTHAA framework was evaluated through user friction analysis. User friction analysis aims to identify the rate at which benign users are forced to perform additional authentication. While step-up authentication introduces moderate friction, blocking a benign user can significantly degrade the user experience, including potential service denial.

The friction metrics were computed as:

$$\text{Step-Up Rate} = \frac{\text{Benign Step-Up Events}}{\text{Total Benign Events}}$$

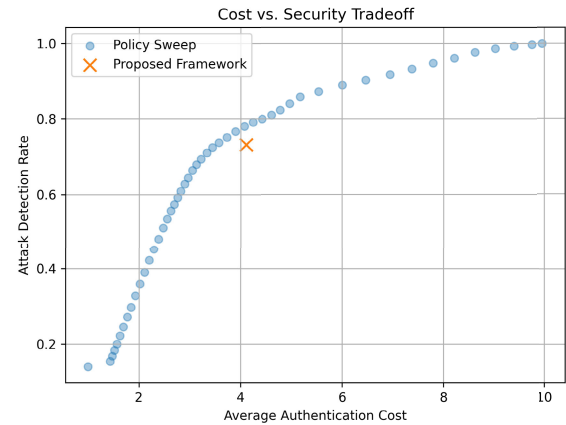
$$\text{False Block Rate} = \frac{\text{Benign Block Events}}{\text{Total Benign Events}}$$

$$\text{Attack Block Rate} = \frac{\text{Attack Block Events}}{\text{Total Attack Events}}$$

A non-linear cost model was adopted to reflect the disproportionate impact of user-facing decisions. Step-up authentication demands on benign users were assigned a moderate cost, while blocking a benign user was assigned a significantly higher cost due to user disruption and denial. Blocking legitimate users is penalized more heavily than step-up authentication, as it directly impacts service availability

TABLE 16. User friction analysis.

Metric	Value
Step-Up Rate	0.1506
False Block Rate	0.0516
Attack Block Rate	0.7314
Average Authentication Cost	4.12

**FIGURE 8. Cost vs attack detection recall.**

and user experience. The cost map used was:

ALLOW : 1, STEP UP : 5, BLOCK : 10

Table 16 captures the user friction metrics, including the cost details.

The usability impact analysis of the data showed that 73% of genuine attacks were blocked by the framework. Approximately 15% of the benign users were challenged to perform additional authentication. About 5% of benign users were blocked from accessing resources.

Fig. 8 illustrates the trade-off between authentication cost and attack detection rate across varying threshold configurations. The plotted curve depicts possible operating points of the framework when thresholds are varied. Each point represents a unique threshold configuration, illustrating the relationship between authentication cost and detection performance. As expected, increasing the strictness of decision thresholds leads to higher detection rates at the expense of increased user friction. The selected operating point (marked with x) achieves a favorable balance, delivering strong detection performance while maintaining a moderate authentication cost.

H. ROBUSTNESS ANALYSIS

Robustness analysis of the proposed framework aimed at assessing how the system responded to parameter changes.

1) ABLATION STUDY

As the system validates contextual signals to arrive at a decision, an ablation study was conducted to measure how the performance changes when the contextual signals

are removed. The study also aimed to confirm that each contextual signal contributes to the system.

Table 17 records how the system responded to the removal of each contextual signal. F1-score and Area Under Curve(AUC) were used as the primary comparison metrics. The system was unaffected by the removal of travel, timezone, and temporal anomalies. The removal of repeated attacker IP resulted in the largest variation in the metrics, followed by Geo anomaly. The session token mismatch showed the next highest variation, followed by fingerprint mismatch. The observations matched with the contextual feature importance computed in Fig. 2.

A further study was conducted by removing group signals, in which all contextual signals related to a specific contextual group were removed. Table 18 presents the observations from the removal of group signals. The observations align with results from the removal of singular contextual signals, with the attack campaign-related group showing the highest impact on F1 and AUC, followed by mobility, which groups geo-anomaly-related signals. The session group showed the next highest impact, followed by temporal and device integrity.

2) ATTACK INTENSITY ANALYSIS

The performance of the framework under increasing attack intensities was studied to understand its response to coordinated attacks. This study exposed the framework to attack intensities varying from 10% to 40%, simulating coordinated attack conditions. Table 19 presents the findings from the study.

The proposed framework demonstrated robust performance under varying attack intensities. The AUC value remains stable, showing that the framework is robust under attack and can distinguish between attack and benign events, even as the proportion of attacks increases. The recall value also remains stable with increasing attack density, indicating that the attack detection capability is consistent. The precision improves, indicating the system becomes more efficient as attacks increase. The accuracy shows slight degradation but remains stable overall.

The results highlight that the proposed framework maintains stable detection performance, while adapting efficiently to increasing complex attack scenarios.

I. COMPARISON WITH BASELINE MODELS

To compare the effectiveness of the proposed ZeTHAA framework, its performance was compared with multiple representative authentication and anomaly detection approaches commonly used in risk-based authentication systems.

1) BASELINE MODELS

The selected baseline methods represent different categories of authentication models. Table 20 lists the baseline models against which the proposed framework is assessed for performance.

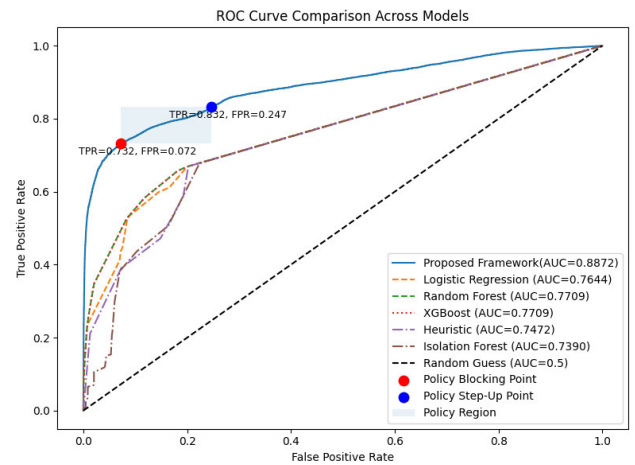


FIGURE 9. ROC comparison across models.

2) DETECTION PERFORMANCE

The performance of the proposed framework and baseline models was evaluated using several commonly used security metrics. All model comparisons were performed on a test set to ensure fair and unbiased evaluation.

Table 21 shows the performance metrics observed comparing the ZeTHAA framework against baselines. The similarity in performance between Random Forest and XGBoost is attributed to the limited feature space and the dominance of a few contextual signals, leading to both models learning identical decision structures.

The ZeTHAA framework outperformed other classification algorithms across most performance metrics. While Random Forest and XGBoost showed a marginal increase in precision, ZeTHAA showed better results recall and F1-score respectively. The ZeTHAA Framework significantly outperforms every other model in Recall, notably beating the Isolation Forest by over 251%. As the Recall is higher, the overall F1-Score (the balance of Precision and Recall) shows a massive jump of 48% to 147% over the comparison. The Logistic Regression and Heuristic approaches performed better than Isolation Forest, which offered the lowest performance metrics among all the approaches.

Fig. 9 records the ROC curve of the ZeTHAA framework compared to the baseline models. The proposed framework records a high true positive rate compared to the other models. The computed decision thresholds are highlighted on the curve, indicating the policy's operating region. At the step-up decision threshold (τ_1) indicated by the blue marker, the framework detects 83.2% of attack events and challenges with step-up verification, while incurring a false positive rate of 24.7%. The True Positive Rate (TPR) and False Positive Rate (FPR) represent aggressive detection, but use step-up authentication and do not block users. The red marker indicates the operating point corresponding to the blocking threshold (τ_2), achieving 73.2% attack detection with a 7.24% false positive rate, showcasing strict security while

TABLE 17. Single signal ablation results.

Removed Signal	Accuracy	Precision	Recall	F1	AUC
None (Full Model)	0.8645	0.8158	0.7313	0.7713	0.8854
Geo_Anomaly	0.7865	0.8159	0.4087	0.5446	0.7584
Travel_Anomaly	0.8645	0.8158	0.7313	0.7713	0.8854
Timezone_Anomaly	0.8645	0.8158	0.7313	0.7713	0.8854
Temporal_Anomaly	0.8645	0.8158	0.7313	0.7713	0.8854
Fingerprint_Mismatch	0.8512	0.8407	0.6461	0.7306	0.8681
Token_Context_Mismatch	0.8079	0.8434	0.4730	0.6061	0.7977
Repeated_Attacker_IP	0.8226	0.7847	0.5955	0.6771	0.7470

TABLE 18. Group signal ablation results.

Removed Group	Accuracy	Precision	Recall	F1	AUC
Mobility	0.7865	0.8159	0.4087	0.5446	0.7584
Temporal	0.8645	0.8158	0.7313	0.7713	0.8854
Device	0.8512	0.8407	0.6461	0.7306	0.8681
Session	0.8079	0.8434	0.4730	0.6061	0.7977
Campaign	0.8226	0.7847	0.5955	0.6771	0.7470

TABLE 19. Attack intensity analysis.

Attack Ratio	Accuracy	Precision	Recall	F1	AUC
0.1	0.9068	0.4012	0.7365	0.5195	0.8867
0.2	0.8916	0.6108	0.7041	0.6542	0.8715
0.3	0.8752	0.7283	0.7042	0.7161	0.8729
0.4	0.8772	0.8394	0.7448	0.7893	0.8937

TABLE 20. Selected baselines for comparison.

Model	Category	Description
Rule-Based RBA	Heuristic	Static weighted contextual scoring
Logistic Regression	Statistical	Probabilistic model estimating attack likelihood
Random Forest	Machine Learning	Tree-based ensemble-learning method
XGBoost	Machine Learning	Optimized gradient boosting algorithm
Isolation Forest	Machine Learning	Unsupervised learning method
Proposed Framework	Zero-Trust Trust Model	Bayesian-calibrated contextual risk model

TABLE 21. Performance comparison between baselines.

Model	Accuracy	Precision	Recall	F1-Score	AUC
Proposed Framework	0.8665	0.8211	0.7320	0.7740	0.8872
Logistic Regression	0.7679	0.7302	0.4073	0.5229	0.7644
Random Forest	0.7803	0.8878	0.3396	0.4913	0.7709
XGBoost	0.7803	0.8878	0.3396	0.4913	0.7709
Isolation Forest	0.7149	0.6324	0.2083	0.3134	0.739
Heuristic	0.7595	0.7082	0.3913	0.5041	0.7472

minimizing user disruption. The shaded portion between the policy thresholds represents the adaptive decision region of the framework. The sharp rise of the proposed framework's ROC curve near the origin indicates early-stage discrimination capability, which helps in minimizing user friction while maintaining high detection rates.

Fig. 10 records the policy decisions taken by the models. The ZeTHAA framework balances security and usability compared to the baseline models. Although it showed a lower "ALLOW" state for events, it had a higher proportion of step-up challenges than the baselines. This shows that events with higher risk scores were automatically asked to perform additional verification. The baseline models

showed a lower range of step-up challenges and block decisions, indicating a conservative approach to security. Unlike traditional classifiers that operate at a single threshold, the ZeTHAA framework defines a controllable decision band, enabling responses based on risk levels and improving detection performance. The ZeTHAA framework produces a well-spread risk distribution, enabling effective utilization of allow, step-up, and block regions. In contrast, baseline models exhibit clustered score distributions. This supports RQ3 and H3, demonstrating improved alignment between risk scores and decision policies. With a more effective use of the intermediate step-up region, the framework further supports RQ2 and H2.

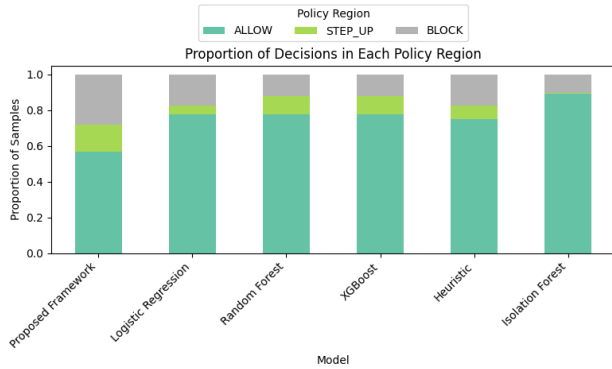


FIGURE 10. Proportion of decisions per policy region.

3) OPERATIONAL EFFICIENCY AND COST PER ATTACK

The operational efficiency of the proposed framework was verified against the baseline models.

Table 22 reports the operational efficiency metrics for the ZeTHAA framework compared with the baseline models. The proposed ZeTHAA framework records the highest step-up and block rates among the models, exceeding 47.9% and 59.9% respectively. However, in the context of the higher recall value, indicating higher attack detection, the higher step-up and block rates can be correlated to increased intervention. The baseline models incur lower costs because they fail to identify and act on a large proportion of attack events. The proposed framework maintains a higher Efficiency (+20% to +65%) but incurs a higher False Block Rate than Random Forest and XGBoost, suggesting a more aggressive yet highly effective detection posture.

The analysis used a non-linear cost model, as adopted earlier in the user friction analysis. The cost map used was {Allow : 1, Stepup : 5, Block : 10}, indicating the cost of asking a benign user for a step-up challenge or blocking him from using the service.

Detection efficiency is defined as the ratio of the Attack detection rate (Recall) to the Average cost of authentication.

$$\text{Efficiency} = \frac{\text{Attack detection rate(Recall)}}{\text{Average authentication cost}}$$

The models were further compared in terms of their average cost, cost per attack detected, and higher efficiency. We define the cost per detected attack as the ratio of the average authentication cost to the attack detection rate.

$$\text{Cost per attack detected} = \frac{\text{Average authentication cost}}{\text{Attack detection rate(Recall)}}$$

Although the average cost per transaction is higher, the “Cost per attack detected” is significantly lower, indicating a 17.3% to 39.6% reduction in cost compared with the other models. However, this increased cost is offset by improved attack detection performance. The cost vs. recall and detection efficiency observations support RQ1 and H1, respectively.

The proposed framework achieves the lowest cost per detected attack among all models. This indicates that although the framework incurs higher overall costs, it uses authentication resources more efficiently to detect attacks. Baseline models exhibit a lower average cost but a higher cost per detected attack, reflecting inefficient security performance. The proposed ZeTHAA framework achieves a higher detection efficiency, indicating a more effective use of authentication resources. The controlled increase in intervention, with significantly improved detection, further demonstrates support of RQ1 and H1.

J. COMPARISON WITH EXISTING FRAMEWORKS

With the ZeTHAA framework exhibiting better performance metrics, operational efficiency, and cost effectiveness against baseline models, we further compare ZeTHAA with methodologies presented in the existing literature. Comparison studies were performed with Dasu et al. [16] and Matiushin and Korkhov [19]. Dasu et al. use a weighted heuristic approach to derive risk scores and make decisions. On the other hand, Matiushin et al. use an ML-based approach to identify anomalies in user behavior and classify requests as an attack or benign. As representatives of two widely used approaches to risk classification - heuristic and ML-based, these works were chosen for the comparison study.

1) DASU ET AL

Dasu et al. utilize five risk signals - travel risk(r_1), location risk(r_2), browser risk(r_3), device risk(r_4), and password risk(r_5). The risk score for each signal is bounded as $\{x \in \mathbb{R} | 0 \leq x \leq 5\}$. Each risk signal is assigned a static weight that represents its relative importance in heuristic scoring.

- Travel Risk (w_1) - 80/33
- Location Risk (w_2) - 40/33
- Browser Risk (w_3) - 20/33
- Device Risk (w_4) - 20/33
- Password Risk (w_5) - 5/33

Travel risk is assigned the highest weight, followed by location, browser, and device risk, with password risk being assigned the least weight. The total risk is then computed as:

$$\text{Total Risk} = (w_1 r_1 + w_2 r_2 + w_3 r_3 + w_4 r_4 + w_5 r_5)$$

The weights are assigned statically, and the framework does not propose an approach to recalibrate them or the binary decision threshold. Risk scores that exceed the threshold are subjected to validation. However, the risk analysis considers only the last 10 login attempts, thereby excluding historical patterns.

To compare the ZeTHAA framework with Dasu et al., we first map the risks to the proposed risk signals. Table 23 presents the mapping of risks from Dasu et al. to ZeTHAA framework’s risk signals.

In the absence of separate browser or device features, fingerprint mismatch is used as a proxy for both. The browser signal is approximated using a device fingerprint mismatch,

TABLE 22. Operational efficiency and cost/attack detected.

Model	Step-Up Rate	Block Rate	False Block Rate	Avg Cost	Recall	Efficiency	Cost/ attack detected
Proposed Framework	0.1514	0.2785	0.0724	4.1118	0.7320	0.1780	5.6172
Logistic Regression	0.0496	0.1742	0.0684	2.7665	0.4073	0.1472	6.7922
Random Forest	0.1023	0.1195	0.0195	2.4848	0.3396	0.1367	7.3168
XGBoost	0.1024	0.1195	0.0195	2.4851	0.3396	0.1367	7.3177
Heuristic	0.0769	0.1726	0.0732	2.8611	0.2083	0.1368	7.3117
Isolation Forest	0.0028	0.1029	0.055	1.937	0.3913	0.1075	9.2990

TABLE 23. Risk to signal mapping.

Dasu et al.	ZeTHAA Dataset
Travel Risk(r_1)	Travel_Anomaly
Location Risk(r_2)	Geo_Anomaly
Browser Risk(r_3)	Fingerprint_Mismatch
Device Risk(r_4)	Fingerprint_Mismatch
Password Risk(r_5)	Token_Context_Mismatch

which captures deviations in client-device characteristics. While the dataset does not explicitly distinguish between browser and device features, fingerprint-based signals provide a reasonable approximation of both.

2) MATIUSHIN ET AL

The Machine Learning-Empowered Risk-Based Authentication (MLE-RBA) framework proposed by Matiushin et al., uses a multi-stage ML pipeline to identify irregularities and make dynamic decisions. It combines two unsupervised ML models: Local Outlier Factor (LOF) and Isolation Forest to capture both local and global deviations in a user's behavior, generating an aggregate anomaly score. This anomaly score is fed into a LightGBM classifier to generate a continuous risk score for every login attempt. Instead of relying on a static, predefined threshold, MLE-RBA dynamically calculates an optimal threshold by evaluating the Receiver Operating Characteristic (ROC) curve. If a login's risk score exceeds this threshold, the system classifies it as an attack and triggers secondary authentication.

3) RESULTS AND OBSERVATIONS

All three frameworks were subjected to the same dataset and cost mapping. The comparisons were conducted under the broad categories of:

a: PERFORMANCE ANALYSIS

Table 24 records the performance metrics recorded by the three frameworks. The proposed ZeTHAA framework exhibited demonstrably higher performance indicators compared to Dasu et al. and MLE-RBA. While MLE-RBA presented a slightly higher precision, indicating accuracy in true positive prediction, ZeTHAA was close behind and fared much better than Dasu et al. ZeTHAA presented a higher recall, indicating an edge in correctly classifying requests.

Table 25 presents the operational efficiency figures for the three frameworks. The ZeTHAA framework presents a higher step-up rate due to an active engagement policy, followed

TABLE 24. Performance metrics comparison.

Model	Accuracy	Precision	Recall	F1-Score	AUC
ZeTHAA	0.8665	0.8211	0.7320	0.7740	0.8872
Dasu et al.	0.7122	0.5667	0.3337	0.4200	0.7037
MLE-RBA	0.7803	0.8878	0.3396	0.4913	0.7704

by MLE-RBA. Dasu et al. presented the lowest step-up rate, indicating that a higher number of requests were classified as benign. ZeTHAA had the highest block rate among the frameworks, while MLE-RBA demonstrated the lowest false block rates, followed by ZeTHAA. However, ZeTHAA exhibited the highest efficiency figures while recording the lowest cost per correctly detected attack. The proposed framework achieves higher recall at comparable cost levels, demonstrating a more favorable security-usability balance and supporting RQ1 and H1.

b: SECURITY POSTURE AND ATTACK DETECTION

Table 26 lists the combined confusion matrix of the three frameworks.

The Proposed ZeTHAA Framework blocks significantly more attacks (7,963) than both the heuristic (Dasu et al.) (3,630) and MLE-RBA (3,695). ZeTHAA is much more aggressive with "Step-Up" challenges for benign users (4,184) than Dasu et al. (240), which corresponds with the higher recall noted in Table 24. ZeTHAA also allows the fewest attacks (1,826) through the system, whereas the others allow over 5,000. MLE-RBA has the lowest FPR (1.95%), indicating it rarely interrupts legitimate users. However, as observed from the Recall value, it misses 66% of attacks to achieve this. ZeTHAA blocked 5% more benign users than MLE-RBA, but in exchange, caught nearly 40% more attacks.

c: ERROR REDUCTION

We further compared the frameworks for their Equal Error Rate (EER). EER represents the point on a ROC curve, where the False Positive Rate (benign users incorrectly blocked) and False Rejection Rate are equal. A lower EER represents a better balance between false accepts and rejects, showcasing the ability to detect attacks while making fewer mistakes on identifying legitimate users.

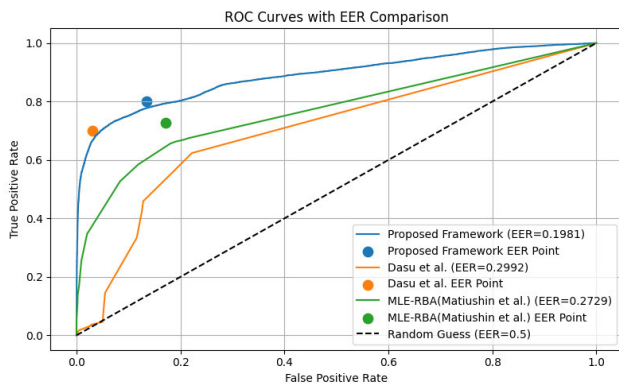
Fig. 11 presents the ROC curves and corresponding EER points for the ZeTHAA, heuristic-based Dasu et al., and ML-based MLE-RBA frameworks. The EER point in the plot represents the balanced operating point at which false positives equal the missed attacks. The proposed framework consistently achieves a higher TPR at

TABLE 25. Operational efficiency comparison.

Model	Step-Up Rate	Block Rate	False Block Rate	Efficiency	Cost/ attack detected
ZeTHAA	0.1514	0.2785	0.0724	0.1780	5.6172
Dasu et al.	0.0356	0.1839	0.1159	0.1193	8.3842
MLE-RBA	0.1049	0.1195	0.0195	0.1361	7.3475

TABLE 26. Combined confusion matrix.

Classification	ZeTHAA		Dasu et al.		MLE-RBA	
	Attack	Benign	Attack	Benign	Attack	Benign
ALLOW	1826	18030	6249	20933	5114	21898
STEP_UP	1090	4184	1000	240	2070	1584
BLOCK	7963	1735	3630	2776	3695	467

**FIGURE 11. ROC curve with EER points.**

a lower FPR, indicating superior discrimination capability. The proposed model achieves the lowest EER (0.1981), significantly outperforming both the heuristic (0.2992) and ML-based approaches (0.2729), supporting RQ2 and H2, which hypothesize improved detection performance and reduced error trade-offs. ZeTHAA reported approximately 33% reduction in error compared to Dasu et al.

The observations show that the proposed framework provides a more favorable balance between false positives and false negatives, improving both security and usability, while achieving higher performance, greater efficiency, and lower operating costs.

VIII. CONCLUSION

Adaptive authentication represents an evolution in security while maintaining usability as a central design factor. This paper presents ZeTHAA, a novel, unified, and formally grounded Zero-Trust-based Adaptive Authentication and continuous authorization framework. By integrating authentication strength, contextual attributes, behavioral evidence, and retry dynamics into a time-dependent trust–risk model, the proposed approach moves beyond heuristic scoring systems. A central contribution is the introduction of a global admissibility predicate, which distinguishes non-compensable hard violations from probabilistic soft signals, thereby enabling clear enforcement decisions. The

entropy and Bayesian-driven parameterization of attribute weights and penalties provides a robust mechanism for cold-start initialization and continuous recalibration, addressing one of the key limitations in existing systems. The framework further establishes a clear separation between intrinsic authentication strength and operational reliability, enabling consistent mapping to NIST assurance levels. With evidence-driven decision thresholds, the framework can capture adversarial behaviors, such as credential stuffing, while tolerating benign user error. The paper highlights how the proposed system extends security and risk assessment well into the resource access phase, a functionality not covered under conventional AA systems. The proposed multiphase hybrid evaluation strategy ensures that the system can validate risk and trust even in the absence of historical context or access patterns. The efficacy of the proposed system was validated on a large-scale synthetic dataset simulating real-world attack conditions. With novel security checks extending to newer attributes, e.g., application integrity and dynamic build secrets, and device posture evaluation, the proposed system minimizes user friction and ensures the user obtains only the minimum degree of trust required to access the intended resources. The proposed ZeTHAA framework provides a coherent, mathematically grounded, and practically implementable approach to ZT-based continuous authentication and authorization.

DECLARATIONS

CONFLICTS OF INTEREST

The authors declare no conflicts of interest.

REFERENCES

- [1] C. Jacomme and S. Kremer, "An extensive formal analysis of multi-factor authentication protocols," *ACM Trans. Privacy Secur.*, vol. 24, no. 2, pp. 1–34, Jan. 2021, doi: [10.1145/3440712](https://doi.org/10.1145/3440712).
- [2] S. S. U. Hasan, A. Ghani, A. Daud, H. Akbar, and M. F. Khan, "A review on secure authentication mechanisms for mobile security," *Sensors*, vol. 25, no. 3, p. 700, Jan. 2025, doi: [10.3390/s25030700](https://doi.org/10.3390/s25030700).
- [3] A. Agarwal, S. B. Verma, and B. K. Gupta, "A review of cloud security issues and challenges," *ADCAIJ, Adv. Distrib. Comput. Artif. Intell. J.*, vol. 12, Dec. 2023, Art. no. e31459, doi: [10.14201/adcaij.31459](https://doi.org/10.14201/adcaij.31459).
- [4] Y. Chen, Y. Yu, and L. Zhai, "Infinitygauntlet: Brute-force attack on smartphone fingerprint authentication," in *Proc. 32nd USENIX Conf. Secur. Symp.*, 2023, pp. 2027–2041. [Online]. Available: <https://dl.acm.org/doi/10.5555/3620237.3620351>

- [5] Q. Wang and D. Wang, "Understanding failures in security proofs of multi-factor authentication for mobile devices," *IEEE Trans. Inf. Forensics Security*, vol. 18, pp. 597–612, 2023, doi: [10.1109/TIFS.2022.3227753](https://doi.org/10.1109/TIFS.2022.3227753).
- [6] D. Wang, X. Zhang, Z. Zhang, and P. Wang, "Understanding security failures of multi-factor authentication schemes for multi-server environments," *Comput. Secur.*, vol. 88, Jan. 2020, Art. no. 101619, doi: [10.1016/j.cose.2019.101619](https://doi.org/10.1016/j.cose.2019.101619).
- [7] M. Syahreen, N. Hafizah, N. Maarop, and M. Maslinan, "A systematic review on multi-factor authentication framework," *Int. J. Adv. Comput. Sci. Appl.*, vol. 15, no. 5, pp. 1043–1050, 2024, doi: [10.14569/ijacsa.2024.01505105](https://doi.org/10.14569/ijacsa.2024.01505105).
- [8] E. B. Blancaflor, J. O. Duldulao, J. V. E. Espeño, G. S. M. Patag, M. T. Menor, and G. L. Intal, "Advanced phishing techniques: Analyzing adversary-in-the-middle and browser-in-the-browser attacks in modern cybersecurity," *Cybern. Inf. Technol.*, vol. 25, no. 1, pp. 55–77, Mar. 2025, doi: [10.2478/cait-2025-0004](https://doi.org/10.2478/cait-2025-0004).
- [9] A. F. Baig and S. Eskeland, "Security, privacy, and usability in continuous authentication: A survey," *Sensors*, vol. 21, no. 17, p. 5967, Sep. 2021, doi: [10.3390/s21175967](https://doi.org/10.3390/s21175967).
- [10] F. Al-Husari, O. Nakov, and P. Nakov, "Multi-factor authentication fatigue: A growing concern in user experience and security," in *Proc. 60th Int. Sci. Conf. Inf., Commun. Energy Syst. Technol. (ICEST)*, Jun. 2025, pp. 1–4, doi: [10.1109/ICEST66328.2025.11098219](https://doi.org/10.1109/ICEST66328.2025.11098219).
- [11] S. Wiefeling, M. Dürmuth, and L. Lo Iacono, "More than just good passwords? A study on usability and security perceptions of risk-based authentication," in *Proc. Annu. Comput. Secur. Appl. Conf.*, Dec. 2020, pp. 203–218, doi: [10.1145/3427228.3427243](https://doi.org/10.1145/3427228.3427243).
- [12] A. Hassan, B. Nuseibeh, and L. Pasquale, "Engineering adaptive authentication," in *Proc. IEEE Int. Conf. Automon Comput. Self-Organizing Syst. Companion (ACSOS-C)*, Sep. 2021, pp. 275–280, doi: [10.1109/ACSOS-C52956.2021.00068](https://doi.org/10.1109/ACSOS-C52956.2021.00068).
- [13] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero trust architecture," National Institute of Standards and Technology, Tech. Rep., 2020. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-207>
- [14] D. Temoshok, D. Proud-Madruga, Y.-Y. Choong, R. Galluzzo, S. Gupta, C. LaSalle, N. Lefkovitz, and A. Regenscheid, "Digital identity guidelines," National Institute of Standards and Technology, Gaithersburg, MD, USA, Tech. Rep. 800-63-4, 2025, doi: [10.6028/NIST.SP.800-63-4](https://doi.org/10.6028/NIST.SP.800-63-4).
- [15] (2021). *Web Authentication: An Api for Accessing Public Key Credentials Level 2*. [Online]. Available: <https://www.w3.org/TR/webauthn-2/>
- [16] L. S. Dasu, M. Dhamija, G. Dishitha, A. Vivekanandan, and V. Sarasvathi, "Defending against identity threats using risk-based authentication," *Cybern. Inf. Technol.*, vol. 23, no. 2, pp. 105–123, Jun. 2023, doi: [10.2478/cait-2023-0016](https://doi.org/10.2478/cait-2023-0016).
- [17] C. Picard and S. Pierre, "RLAuth: A risk-based authentication system using reinforcement learning," *IEEE Access*, vol. 11, pp. 61129–61143, 2023, doi: [10.1109/ACCESS.2023.3286376](https://doi.org/10.1109/ACCESS.2023.3286376).
- [18] V. Unsel, S. Wiefeling, N. Gruschka, and L. Lo Iacono, "Risk-based authentication for OpenStack: A fully functional implementation and guiding example," in *Proc. 13th ACM Conf. Data Appl. Secur. Privacy*, Apr. 2023, pp. 237–243, doi: [10.1145/3577923.3583634](https://doi.org/10.1145/3577923.3583634).
- [19] I. Matiushin and V. Korkhov, "MLE-RBA: A machine learning-empowered risk-based authentication algorithm," in *Proc. Comput. Sci. Appl.-ICCSA Workshops*, 2025, pp. 325–339, doi: [10.1007/978-3-031-97648-3_22](https://doi.org/10.1007/978-3-031-97648-3_22).
- [20] Y. Zhang, F. Wang, J. Zeng, L. Chen, X. Huang, Z. Li, and K. Xue, "User behavior-based dynamic authentication design for enhanced identity security," in *Proc. IEEE Int. Conf. Commun.*, Jun. 2025, pp. 1–6, doi: [10.1109/ICC52391.2025.11161955](https://doi.org/10.1109/ICC52391.2025.11161955).
- [21] M. Papaioannou, G. Zachos, G. Mantas, and J. Rodriguez, "Novelty detection for risk-based user authentication on mobile devices," in *Proc. IEEE Global Commun. Conf.*, Dec. 2022, pp. 837–842, doi: [10.1109/GLOBECOM48099.2022.10000843](https://doi.org/10.1109/GLOBECOM48099.2022.10000843).
- [22] Q. I. M. Hussain and V. Kale, "Risk-based adaptive authentication in mobile network system using dynamic elliptic curve digital signature algorithm," *Concurrency Comput., Pract. Exper.*, vol. 37, nos. 21–22, p. 70208, Sep. 2025. [Online]. Available: <https://onlinelibrary.wiley.com/doi/abs/10.1002/cpe.70208>
- [23] M. Papaioannou, G. Mantas, and J. Rodriguez, "Risk-based user authentication for mobile passenger ID devices for land and sea border control," in *Proc. IEEE Int. Medit. Conf. Commun. Neww. (MeditCom)*, Sep. 2021, pp. 180–185, doi: [10.1109/MEDITCOM49071.2021.9647603](https://doi.org/10.1109/MEDITCOM49071.2021.9647603).
- [24] A. A. Megahed, M. F. Arnous, Y. Elmoataz, A. Moussa, S. Haitham, and M. Hany, "Enhanced security through intelligent risk-based authentication: Leveraging big data and machine learning for real-time threat mitigation," in *Proc. 6th Novel Intell. Lead. Emerg. Sci. Conf. (NILES)*, Oct. 2024, pp. 246–249.
- [25] M. Al-Zubaidie, Z. Zhang, and J. Zhang, "RAMHU: A new robust lightweight scheme for mutual users authentication in healthcare applications," *Secur. Commun. Netw.*, vol. 2019, pp. 1–26, Mar. 2019. [Online]. Available: <https://onlinelibrary.wiley.com/doi/abs/10.1155/2019/3263902>
- [26] A. Acar, H. Aksu, A. S. Uluagac, and K. Akkaya, "A usable and robust continuous authentication framework using wearables," *IEEE Trans. Mobile Comput.*, vol. 20, no. 6, pp. 2140–2153, Jun. 2021.
- [27] A. Buriro, S. Gupta, A. Yautsiukhin, and B. Crispo, "Risk-driven behavioral biometric-based one-shot-cum-continuous user authentication scheme," *J. Signal Process. Syst.*, vol. 93, no. 9, pp. 989–1006, Sep. 2021, doi: [10.1007/s11265-021-01654-2](https://doi.org/10.1007/s11265-021-01654-2).
- [28] Z. Shen, S. Li, X. Zhao, and J. Zou, "MMAuth: A continuous authentication framework on smartphones using multiple modalities," *IEEE Trans. Inf. Forensics Security*, vol. 17, pp. 1450–1465, 2022, doi: [10.1109/TIFS.2022.3160361](https://doi.org/10.1109/TIFS.2022.3160361).
- [29] Y. Liang, S. Samtani, B. Guo, and Z. Yu, "Behavioral biometrics for continuous authentication in the Internet-of-Things era: An artificial intelligence perspective," *IEEE Internet Things J.*, vol. 7, no. 9, pp. 9128–9143, Sep. 2020, doi: [10.1109/JIOT.2020.3004077](https://doi.org/10.1109/JIOT.2020.3004077).
- [30] M. Mekni, E. O. Ogunwobi, and S. C. Russell, "Context-adaptive gait biometrics for real-time continuous authentication," in *Proc. Int. Conf. Adv. Mach. Learn. Data Sci. (AMLDS)*, Jul. 2025, pp. 799–807.
- [31] S. W. Shah, N. F. Syed, A. Shaghghi, A. Anwar, Z. Baig, and R. Doss, "LCDA: Lightweight continuous device-to-device authentication for a zero trust architecture (ZTA)," *Comput. Secur.*, vol. 108, Sep. 2021, Art. no. 102351, doi: [10.1016/j.cose.2021.102351](https://doi.org/10.1016/j.cose.2021.102351).
- [32] G. Dahia, L. Jesus, and M. Pamplona Segundo, "Continuous authentication using biometrics: An advanced review," *WIREs Data Mining Knowl. Discovery*, vol. 10, no. 4, p. 1365, Jul. 2020, doi: [10.1002/widm.1365](https://doi.org/10.1002/widm.1365).
- [33] A. F. Baig, S. Eskeland, and B. Yang, "Privacy-preserving continuous authentication using behavioral biometrics," *Int. J. Inf. Secur.*, vol. 22, no. 6, pp. 1833–1847, Dec. 2023, doi: [10.1007/s10207-023-00721-y](https://doi.org/10.1007/s10207-023-00721-y).
- [34] S. Ayeswarya and K. J. Singh, "A comprehensive review on secure biometric-based continuous authentication and user profiling," *IEEE Access*, vol. 12, pp. 82996–83021, 2024, doi: [10.1109/ACCESS.2024.3411783](https://doi.org/10.1109/ACCESS.2024.3411783).
- [35] S. Ambol and S. Rashad, "Continuous authentication of smartphone users using machine learning," in *Proc. 11th IEEE Annu. Ubiquitous Comput., Electron. Mobile Commun. Conf. (UEMCON)*, Oct. 2020, pp. 0056–0062, doi: [10.1109/UEMCON51285.2020.9298040](https://doi.org/10.1109/UEMCON51285.2020.9298040).
- [36] S. Hasan, I. Amundson, and D. Hardin, "Zero-trust design and assurance patterns for cyber-physical systems," *J. Syst. Archit.*, vol. 155, Oct. 2024, Art. no. 103261. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S138376212400198X>
- [37] P. Phaiyura and S. Teerakanok, "A comprehensive framework for migrating to zero trust architecture," *IEEE Access*, vol. 11, pp. 19487–19511, 2023.
- [38] Z. Adahman, A. W. Malik, and Z. Anwar, "An analysis of zero-trust architecture and its cost-effectiveness for organizational security," *Comput. Secur.*, vol. 122, Nov. 2022, Art. no. 102911. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0167404822003042>
- [39] C. Liu, R. Tan, Y. Wu, Y. Feng, Z. Jin, F. Zhang, Y. Liu, and Q. Liu, "Dissecting zero trust: Research landscape and its implementation in IoT," *Cybersecurity*, vol. 7, no. 1, p. 20, May 2024, doi: [10.1186/s42400-024-00212-0](https://doi.org/10.1186/s42400-024-00212-0).
- [40] W. Yeoh, M. Liu, M. Shore, and F. Jiang, "Zero trust cybersecurity: Critical success factors and a maturity assessment framework," *Comput. Secur.*, vol. 133, Oct. 2023, Art. no. 103412, doi: [10.1016/j.cose.2023.103412](https://doi.org/10.1016/j.cose.2023.103412).
- [41] E. W. Tomlinson, W. D. Abhra, S. D. Kim, and S. A. Ortega, "Cybersecurity access control: Framework analysis in a healthcare institution," *J. Cybersecurity Privacy*, vol. 4, no. 3, pp. 762–776, Sep. 2024, doi: [10.3390/jcp4030035](https://doi.org/10.3390/jcp4030035).
- [42] Y. Kim, S.-G. Sohn, K. T. Kim, H. S. Jeon, S.-M. Lee, Y. Lee, and J. Kim, "Exploring effective zero trust architecture for defense cybersecurity: A study," *KSII Trans. Internet Inf. Syst.*, vol. 18, no. 9, pp. 2665–2691, Sep. 2024, doi: [10.3837/tiis.2024.09.011](https://doi.org/10.3837/tiis.2024.09.011).

- [43] B. Hale, D. L. Van Bossuyt, N. Papakonstantinou, and B. O'Halloran, "A zero-trust methodology for security of complex systems with machine learning components," in *Proc. 41st Comput. Inf. Eng. Conf. (CIE)*, Aug. 2021, p. 002, doi: [10.1115/detc2021-70442](https://doi.org/10.1115/detc2021-70442).
- [44] V. Krishnan and C. S. Sreeja, "Zero trust-based adaptive authentication using composite attribute set," in *Proc. IEEE 3rd PhD Colloq. Ethically Driven Innov. Technol. Soc. (PhD EDITS)*, Nov. 2021, pp. 1–2, doi: [10.1109/PHDEDITS53295.2021.9649474](https://doi.org/10.1109/PHDEDITS53295.2021.9649474).
- [45] I. Ahmed, T. Nahar, S. S. Urmi, and K. A. Taher, "Protection of sensitive data in zero trust model," in *Proc. Int. Conf. Comput. Advancements*, Jan. 2020, pp. 1–5, doi: [10.1145/3377049.3377114](https://doi.org/10.1145/3377049.3377114).
- [46] A. Qazi and S. Arshad, "Implementation of enhanced security measures in Oracle ERP cloud with zero trust architecture (ZTA)," in *Proc. Int. Conf. Commun. Technol. (ComTech)*, Apr. 2025, pp. 1–6.
- [47] A. Farraj, "On using zero trust to securing industrial control systems in the power systems industry," in *Proc. IEEE Texas Power Energy Conf. (TPEC)*, Feb. 2025, pp. 1–5, doi: [10.1109/TPEC63981.2025.10906998](https://doi.org/10.1109/TPEC63981.2025.10906998).
- [48] M. A. Aleisa, "Blockchain-enabled zero trust architecture for privacy-preserving cybersecurity in IoT environments," *IEEE Access*, vol. 13, pp. 18660–18676, 2025, doi: [10.1109/ACCESS.2025.3529309](https://doi.org/10.1109/ACCESS.2025.3529309).
- [49] M. Tsai, S. Lee, and S. W. Shieh, "Strategy for implementing of zero trust architecture," *IEEE Trans. Rel.*, vol. 73, no. 1, pp. 93–100, Mar. 2024, doi: [10.1109/TR.2023.3345665](https://doi.org/10.1109/TR.2023.3345665).
- [50] A. Hassan, A. Rauf, N. Shafqat, R. Latif, and H. Khan, "ZenGuard a machine learning based zero trust framework for context aware threat mitigation using SIEM SOAR and UEBA," *Sci. Rep.*, vol. 15, no. 1, p. 35871, Oct. 2025, doi: [10.1038/s41598-025-20998-4](https://doi.org/10.1038/s41598-025-20998-4).
- [51] N. F. Syed, S. W. Shah, A. Shaghaghi, A. Anwar, Z. Baig, and R. Doss, "Zero trust architecture (ZTA): A comprehensive survey," *IEEE Access*, vol. 10, pp. 57143–57179, 2022.
- [52] E. Hosney, I. Halim, and A. H. Yousef, "An artificial intelligence approach for deploying zero trust architecture (ZTA)," in *Proc. 5th Int. Conf. Comput. Inform. (ICCI)*, Mar. 2022, pp. 343–350.
- [53] E. Bertino, "Zero trust architecture: Does it help?" *IEEE Secur. Privacy*, vol. 19, no. 5, pp. 95–96, Sep. 2021, doi: [10.1109/MSEC.2021.3091195](https://doi.org/10.1109/MSEC.2021.3091195).
- [54] L. Bradatsch, O. Miroshkin, N. Trkulja, and F. Kargl, "Zero trust score-based network-level access control in enterprise networks," in *Proc. IEEE 22nd Int. Conf. Trust, Secur. Privacy Comput. Commun. (TrustCom)*, CA, Los Alamitos, CA, USA: IEEE Computer Society, Nov. 2023, pp. 1422–1429. [Online]. Available: <https://doi.ieeeecomputersociety.org/10.1109/TrustCom60117.2023.00194>
- [55] Q. Yao, Q. Wang, X. Zhang, and J. Fei, "Dynamic access control and authorization system based on zero-trust architecture," in *Proc. Int. Conf. Control, Robot. Intell. Syst.*, Oct. 2020, pp. 123–127, doi: [10.1145/3437802.3437824](https://doi.org/10.1145/3437802.3437824).
- [56] *Special Publication 800-63b: Digital Identity Guidelines: Authentication and Authenticator Management*, National Institute of Standards and Technology, Gaithersburg, MD, USA, 2025, doi: [10.6028/NIST.SP.800-63B-4](https://doi.org/10.6028/NIST.SP.800-63B-4).
- [57] National Institute of Standards and Technology. (2012). *Guide for Conducting Risk Assessments*. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>
- [58] National Institute of Standards and Technology. (2018). *Risk Management Framework for Information Systems and Organizations*. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-37r2.pdf>
- [59] (2024). *OWASP Authentication Cheat Sheet*. [Online]. Available: <https://cheatsheetseries.owasp.org/cheatsheets/AuthenticationCheatSheet.html>
- [60] N. Harwood-Nash. (Jun. 2023). *How Fast Do Planes Fly*. [Online]. Available: <https://airadvisor.com/en/blog/how-fast-do-planes-fly>
- [61] V. Krishnan. (2026). *ZeTHAA*. [Online]. Available: <https://github.com/vivinkrishnan/ZETHAA>



VIVIN KRISHNAN received the master's degree in technology from Cochin University of Science and Technology. He is currently a Software Architect with Numentica Technologies, Bengaluru. He is a Research Scholar at CHRIST (Deemed to be University), Bengaluru. He has more than 18 years of IT experience. His areas of interest include information security, authentication, and scalable software systems.



C. S. SREEJA (Senior Member, IEEE) received the Ph.D. degree from CHRIST (Deemed to be University), Bengaluru, which focused on Information security aspects. She is an Assistant Professor with the Quantum Technologies and Complex Systems (CQTCS), CHRIST (Deemed to be University), where she has been a Faculty Member, since 2019. She has published her research work in peer-reviewed journals, including Elsevier and Inderscience, and in the proceedings of renowned International conferences by IEEE, Springer, and ACM. Her area of expertise in research includes, but is not limited to, information security, authentication, public key cryptography, E-signature, bio-molecular computing, DNA cryptography, and blockchain. She also received the IEEE best thesis award (second) for her Ph.D. Thesis during the Graduate Congress GraTE '7' 2019. She also served as a reviewer for prestigious IEEE Conferences, the Session Chair, and the Publications Co-Chair for the IEEE PhD Colloquium on Ethically Driven Innovation and Technology for Society 2019 and 2020. She is an active member of the IEEE ComSoc Bangalore Chapter.

...